ФГБОУ ВО «Московский технологический университет»
Институт кибербезопасности и цифровых технологий

Кафедра КБ-1 «Защита информации»

Дисциплина: «Разработка и эксплуатация автоматизированных систем в защищенном исполнении»

Отчет по практическое работе №2

Тема: “Разработка частного технического задания на создание системы защиты персональных данных автоматизированной системы учета кадров маркетинговой компании”

Вариант задания №10

Выполнил:
Студент группы БАСО-04-22
Кузнецов Алексей Александрович

Проверил:
доцент Федин Ф.О.

Москва, 2025

Учебная цель занятия: Углубить теоретические знания и выработать практические умения в области разработки технического задания на создание системы защиты персональных данных автоматизированной системы.

Место проведения занятия: компьютерная аудитория.

Учебно-материальное обеспечение:

1) Методические указания.

2) Автоматизированное рабочее место в компьютерном классе.

3) Стандартный пакет MS Office или OpenOffice.org.

Задание №1. Разработать пункты 1-10 технического задания на систему защиты ПДн в АСЗИ своего варианта.

Выполнить оформление титульного листа и полного текста частного технического задания на систему защиты персональных данных в автоматизированной системе своего варианта.

Ход выполнения задания

УТВЕРЖДАЮ
Генеральный директор
ООО «Маркетинг с умом»
А.А. Смирнов

«___»_____ 202__ г.

М.П.

УТВЕРЖДАЮ
Руководитель
ООО «Технологии и системы»
А.А. Кузнецов

«___»_____ 202__ г.

М.П.

ЧАСТНОЕ ТЕХНИЧЕСКОЕ ЗАДАНИЕ НА СОЗДАНИЕ СИСТЕМЫ ЗАЩИТЫ ПЕРСОНАЛЬНЫХ ДАННЫХ АВТОМАТИЗИРОВАННОЙ СИСТЕМЫ В ЗАЩИЩЕННОМ ИСПОЛНЕНИИ ДЛЯ УЧЕТА КАДРОВ МАРКЕТИНГОВОЙ КОМПАНИИ ООО «МАРКЕТИНГ С УМОМ»

СОГЛАСОВАНО

_____/
_____
«___»_____ 202__ г.

Представители предприятия-разработчика

_____/
_____
«___»_____ 202__ г.

_____/
_____
«___»_____ 202__ г.

202__ г.

Содержание

1 Общие сведения 8
1.1 Полное наименование системы и ее условное обозначение 8
1.2 Номер договора 9
1.3 Наименование предприятий разработчика и заказчика системы и их реквизиты 9
1.4 Перечень документов, на основании которых создается система 9
1.5 Плановые сроки начала и окончания работ по созданию системы 11
1.6 Порядок оформления и предъявления заказчику результатов работ по созданию системы 11
2 Назначение и цели создания системы 13
2.1 Назначение системы 13
2.2 Цели создания системы 13
3 Характеристика объекта автоматизации 15
3.1 Состав подсистем АСЗИ 15
3.2 Охрана и пропускной режим 16
3.3 Контролируемая зона 16
3.4 Модель угроз безопасности персональных данных в АСЗИ 17
4 Требования к системе 61
4.1 Требования к составу и содержанию мер по обеспечению безопасности ПДн, необходимых для обеспечения уровня защищенности ПДн, установленного для АСЗИ 61
4.2 Требования к мерам по идентификации и аутентификации субъектов доступа и объектов доступа 64
4.3 Требования к мерам по управлению доступом субъектов доступа к объектам доступа 68
4.4 Требования к мерам по ограничению программной среды 68
4.5 Требования к мерам по защите машинных носителей персональных данных (средств обработки (хранения) персональных данных, съемных машинных носителей персональных данных) 68

4.6 Требования к мерам по регистрации событий безопасности 69
4.7 Требования к мерам по антивирусной защите 69
4.8 Требования к мерам по обнаружению (предотвращению) вторжений 69
4.9 Требования к мерам по контролю (анализу) защищенности персональных данных 70
4.10 Требования к мерам по обеспечению целостности информационной системы и персональных данных 70
4.11 Требования к мерам по обеспечению доступности персональных данных 71
4.12 Требования к мерам по защите среды виртуализации 71
4.13 Требования к мерам по защите технических средств 71
4.14 Требования к мерам по защите информационной системы, ее средств, систем связи и передачи данных 72
4.15 Требования к мерам по выявлению инцидентов и реагированию на них 72
4.16 Требования к мерам по управлению конфигурацией информационной системы и системы защиты персональных данных 72
4.17 Требования к структуре и функционированию СЗПДн АСЗИ 73
4.17.1 Перечень систем, подсистем СЗПДн АСЗИ, их назначение и основные характеристики 73
4.17.2 Требования к способам и средствам связи для информационного обмена между компонентами системы 76
4.17.3 Требования к характеристикам взаимосвязей создаваемой системы со смежными системами 77
4.17.4 Требования к режимам функционирования системы 77
4.17.5 Перспективы развития и модернизации системы 77
4.17.6 Требования по стандартизации и унификации 78
4.17.7 Требования к численности и квалификации персонала системы и режиму его работы 79
4.17.8 Требования к показателям назначения системы 79

4.17.9 Требования к надежности 80
4.17.10 Требования к эксплуатации, техническому обслуживанию, ремонту и хранению элементов системы 80
4.18 Требования к видам обеспечения 81
4.18.1 Требования к техническому обеспечению 81
4.18.2 Требования к программному обеспечению 82
4.18.3 Требования к методическому и другим видам обеспечения 83
5 Состав и содержание работ по созданию системы 84
6 Порядок контроля и приемки системы 86
6.1 Виды испытаний системы 86
6.1.1 Состав, объем и методы испытаний системы 86
6.1.2 Предварительные испытания системы 87
6.1.3 Опытная эксплуатация системы 87
6.1.4 Приемочные испытания системы 88
6.2 Общие требования к приемке работ по стадиям 88
6.2.1 Перечень участвующих предприятий и организаций 89
6.2.2 Место и сроки проведения испытаний 89
6.2.3 Порядок согласования и утверждения приемочной документации . 90
7 Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу СЗПДн АСЗИ в действие 91
8 Требования к документированию 92
9 Источники разработки 93
10 Перечень принятых сокращений и условных обозначений 95

1 Общие сведения

Настоящее **Частное техническое задание (ЧТЗ)** является основным документом, определяющим требования и порядок создания системы защиты персональных данных (СЗПДн) автоматизированной системы в защищенном исполнении (АСЗИ) для учета кадров маркетинговой компании ООО «Маркетинг с умом», в соответствии с которым проводится ее разработка и приемка при вводе в эксплуатацию.

Результатом создания системы защиты персональных данных автоматизированной системы учета кадров маркетинговой компании ООО «Маркетинг с умом» должна стать полностью работоспособная система защиты персональных данных автоматизированной системы в защищенном исполнении для учета кадров маркетинговой компании ООО «Маркетинг с умом», соответствующая требованиям настоящего технического задания, а также нормативных документов в области защиты информации.

Согласно ГОСТ 34.602-2020, изменения к техническому заданию (ЧТЗ) на создание системы защиты персональных данных оформляют дополнением или подписанным заказчиком и разработчиком протоколом. Дополнение или указанный протокол являются неотъемлемой частью технического задания на систему защиты персональных данных автоматизированной системы в защищенном исполнении для учета кадров маркетинговой компании ООО «Маркетинг с умом».

1.1 Полное наименование системы и ее условное обозначение

Полное наименование системы: Система защиты персональных данных автоматизированной системы в защищенном исполнении для учета кадров маркетинговой компании ООО «Маркетинг с умом».

Условное обозначение системы: СЗПДн АСЗИ.

1.2 Номер договора

Настоящее ЧТЗ разработано на основании договора №1/11/11-2025 между ООО «Технологии и системы» и ООО «Маркетинг с умом» от 11 ноября 2025 г.

1.3 Наименование предприятий разработчика и заказчика системы и их реквизиты

Заказчик: ООО «Маркетинг с умом». Адрес места нахождения: 119530, г. Москва, Очаковское шоссе, д. 34. Фактический адрес: 119530, г. Москва, Очаковское шоссе, д. 34.

Разработчик: ООО «Технологии и системы». Адрес места нахождения: 107996, г. Москва, ул. Стромынка, 20.

1.4 Перечень документов, на основании которых создается система

Федеральный закон РФ №152-ФЗ «О персональных данных» от 27.07.2006.

Федеральный закон РФ №98-ФЗ «О коммерческой тайне» от 29.07.2004.

Постановление Правительства РФ №1119 от 01.11.2012 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».

Приказ ФСТЭК России №21 от 18.02.2013 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных».

Приказ ФСБ России №378 от 10.07.2014 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных

Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности».

ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения».

ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы».

Таблица 1 – Этапы работ по созданию СЗПДн АСЗИ.

№ п/п	Этапы работ по созданию СЗПДн
1	Обследование процессов обработки персональных данных (ПДн)
2	Построение модели угроз безопасности ПДн
3	Разработка ЧТЗ на создание СЗПДн
4	Разработка Технического проекта
5	Разработка ОРД по ПДн
6	Разработка Рабочей документации
7	Подготовка объекта автоматизации к вводу СЗПДн в действие
8	Комплектация СЗПДн поставляемыми изделиями
9	Строительно-монтажные работы
10	Пуско-наладочные работы
11	Аттестационные испытания СЗПДн

Выполнение перечисленных выше этапов работ по организации обеспечения безопасности персональных данных ООО «Маркетинг с умом» осуществляется в рамках следующих лицензий Исполнителя:

- Лицензия ФСТЭК России на деятельность по технической защите конфиденциальной информации (бланк серия КИ 0066 № 003267, регистрационный № 1244 от 24.09.2020, действительна до 24.09.2030);

- Лицензия ФСТЭК России на деятельность по разработке и (или) производству средств защиты конфиденциальной информации (бланк серия КИ 0066 № 003268, регистрационный № 0743 от 24.09.2020, действительна до 24.09.2030);

- Лицензия УФСБ России по Самарской области на осуществление деятельности по распространению шифровальных (криптографических)

средств (бланк серия ЛЗ № 0011980, регистрационный № 305Р от 10.08.2020, действительна до 10.08.2032);

- Лицензия УФСБ России по Московской области на осуществление деятельности по предоставлению услуг в области шифрования информации (бланк серия ЛЗ № 0011979, регистрационный № 307У от 10.08.2020, действительна до 10.08.2032);

- Лицензия УФСБ России по Московской области на осуществление деятельности по распространению шифровальных (криптографических) средств (бланк серия ЛЗ № 0011978, регистрационный № 306Х от 10.08.2020, действительна до 10.08.2030).

Остальные этапы работ по созданию СЗПДн АСЗИ проводятся в рамках отдельно заключаемых договоров.

1.5 Плановые сроки начала и окончания работ по созданию системы

Сроки начала работ по созданию СЗПДн АСЗИ определяются в соответствии с договором № 1/10/10-2025 между ООО «Технологии и системы» и ООО «Маркетинг с умом» от 10 октября 2025 г.

Сроки окончания работ по созданию СЗПДн АСЗИ организации определяются в соответствии с заключаемыми на выполнение соответствующих работ договорами.

1.6 Порядок оформления и предъявления заказчику результатов работ по созданию системы

Документация, предъявляемая Заказчику, должна быть разработана и оформлена в соответствии с требованиями следующих документов:

- Требования к защите персональных данных при их обработке в информационных системах персональных данных, утвержденные постановлением Правительства Российской Федерации от 1 ноября 2012 года № 1119;

- Состав и содержание организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных (утверждены приказом ФСТЭК России №21 от 18 февраля 2013 года);

- ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения»;

- ГОСТ 34.602-2020 «Информационная технология. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы»;

- ГОСТ 34.201-2020 «Информационная технология. Комплекс стандартов на автоматизированные системы. Виды, комплектность и обозначение документов при создании автоматизированных систем»;

- ГОСТ Р 59793-2021 «Информационная технология. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания»;

- ГОСТ Р 59795-2021 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Требования к содержанию документов».

Документы, являющиеся результатом работ, предоставляются Исполнителем Заказчику в 2-х экземплярах на бумажных носителях и в 1-м экземпляре на электронном носителе. Документы в электронном виде предоставляются в форматах *pdf на USB-носителях.

2 Назначение и цели создания системы

Раздел содержит сведения о назначении создаваемой системы защиты персональных данных (СЗПДн) и определяет цели её разработки и внедрения. В данном разделе описываются функции, которые система должна выполнять, а также основные задачи, решаемые при её создании. Устанавливаются ожидаемые результаты внедрения и общие направления совершенствования защиты персональных данных автоматизированной системы в защищенном исполнении для учета кадров маркетинговой компании ООО «Маркетинг с умом».

2.1 Назначение системы

СЗПДн АСЗИ для учета кадров маркетинговой компании предназначена для обеспечения комплексной защиты информации, содержащей персональные данные (ПДн) и сведения, составляющие коммерческую тайну (КТ), на всех этапах их обработки. Система реализует совокупность организационных, программных и технических мер, направленных на предотвращение:

– Несанкционированного доступа (НСД) к ПДн;

– Утечки информации через технические и программные каналы;

– Модификации, уничтожения или блокирования данных вследствие ошибок персонала или воздействия вредоносного программного обеспечения (ВПО);

– Нарушений целостности, доступности и конфиденциальности данных при передаче и хранении.

2.2 Цели создания системы

Основной целью создания СЗПДн является приведение процессов обработки персональных данных в АСЗИ в соответствие с требованиями законодательства Российской Федерации, а также обеспечение надёжной защиты информации от внутренних и внешних угроз.

Ключевые цели создания системы:

– Организационная защита - разработка и внедрение организационно-распорядительных документов, регламентирующих порядок обработки и защиты персональных данных в компании;

– Техническая защита - реализация комплекса программных и аппаратных средств, обеспечивающих конфиденциальность, целостность и доступность ПДн;

– Нормативное соответствие - обеспечение выполнения требований Федерального закона №152-ФЗ, Постановления Правительства РФ №1119 и приказов ФСТЭК России №21 и ФСБ России №378;

– Разграничение доступа - введение ролевой модели доступа, обеспечивающей минимально необходимый доступ к данным в зависимости от должностных обязанностей сотрудников;

– Мониторинг и аудит - создание системы регистрации событий безопасности и аудита действий пользователей и администраторов;

– Обеспечение отказоустойчивости - внедрение процедур резервного копирования и восстановления информации после сбоев и чрезвычайных ситуаций;

– Снижение рисков инцидентов безопасности - минимизация вероятности утечки, потери или уничтожения информации, а также последствий инцидентов информационной безопасности.

3 Характеристика объекта автоматизации

Обработку ПДн в АСЗИ планируется осуществлять на объектах Заказчика, приведенных в таблице 2.

Таблица 2 – Территориально-распределенные объекты Заказчика

№ п/п	Наименование объекта	Место размещения (адрес)
1	Отдел кадров	119530, Москва, Очаковское шоссе, д. 34, помещение №29
2	Отдел автоматизации	119530, Москва, Очаковское шоссе, д. 34, помещение №35
3	Служба безопасности	119530, Москва, Очаковское шоссе, д. 35, помещение №13

В настоящее время обработка ПДн в АСЗИ осуществляется на всех территориально-распределенных объектах, приведенных в таблице 2. Перечень территориально-распределенных объектов, для которых осуществляется создание СЗПДн АСЗИ, определяется Заказчиком на этапе разработки Технического проекта.

Обработка защищаемых ПДн осуществляется в АСЗИ.

Объем обрабатываемых персональных данных в системе – менее 100000 субъектов.

Территориальное размещение АСЗИ – локальная (кампусная) СЗПДн АСЗИ, развернутая в пределах нескольких близко расположенных зданий.

Наличие соединения с сетями общего пользования – АСЗИ, имеющая одноточечный выход в сеть общего пользования.

Разграничение доступа к ПДн – АСЗИ, к которой имеет доступ определенный перечень сотрудников организации, являющейся владельцем АСЗИ, либо субъект ПДн.

3.1 Состав подсистем АСЗИ

Состав подсистем АСЗИ приведен в таблице 3.

Таблица 3 – Подсистемы АСЗИ

№ п/п	Наименование подсистемы
1.	Подсистема защиты информации
2.	Подсистема регистрации заявок

Продолжение таблицы 3

№ п/п	Наименование подсистемы
3.	Подсистема обработки документов
4.	Подсистема отчетности
5.	База данных АСЗИ

Совокупность ПДн, обрабатываемых в АСЗИ (хранимых и передаваемых), технических и программных средств, входящих в состав АСЗИ, а также компонентов создаваемой СЗПДн АСЗИ, составляет защищаемые информационные ресурсы.

3.2 Охрана и пропускной режим

Охрана объекта должна осуществляться специализированным охранным предприятием, имеющим штат профессиональных сотрудников и разрешительные документы, позволяющие осуществлять охранную деятельность.

Пропускной режим должен позволять:

- контролировать поток посетителей МК, отслеживать пронос запрещенных предметов, ввоз и вывоз материальных ценностей, предотвращать несанкционированный доступ к объекту;

- своевременно реагировать на любые неблагоприятные тенденции и потенциальные угрозы.

Охранная сигнализация должна обеспечивать обнаружение проникновения (попытки проникновения) на охраняемый объект, сбор, обработку, передачу и представление в заданном виде служебной информации и информации о проникновении (попытки проникновения).

3.3 Контролируемая зона

Контролируемая зона представлена в виде периметра стен помещений.

3.4 Модель угроз безопасности персональных данных в АСЗИ

Настоящий раздел является методикой моделирования угроз и нарушителя безопасности информации АСЗИ и разработан с учетом условий и особенностей функционирования информационных систем компании, обрабатывающих различные информационные активы, с учетом требований законодательства Российской Федерации в области обеспечения информационной безопасности, методического документа ФСТЭК России от 05 февраля 2021 г. «Методика оценки угроз безопасности информации».

Целью моделирования угроз безопасности информации является выявление условий и факторов, вероятных инцидентов, приводящих к нарушению безопасности информации (нарушению конфиденциальности, целостности, доступности, аутентичности, достоверности) и средств ее обработки.

Оценивание угроз информационной безопасности осуществляется в целях определения угроз безопасности, реализация которых возможна и может нанести ущерб рассматриваемой системе коммерческой организации, с описанной выше архитектурой и условиями функционирования.

Процесс моделирования угроз и нарушителя безопасности информации включается в себя несколько этапов, которые описаны в таблице 4:

- определение возможных негативных последствий в результате реализации угроз безопасности информации;
- определение возможных объектов воздействия угроз;
- оценку возможности реализации угроз и определение их актуальности.

Таблица 4 – Процесс моделирования угроз и нарушителя безопасности информации

Исходные данные	Этап	Результат
Требования законодательства РФ, сведения о составе, структуре и функционале АСЗИ компании, сведения о защищаемых активах	Определение возможных негативных последствий реализации угроз	Перечень негативных последствий
		Виды рисков (ущерба)

Продолжение таблицы 4

Исходные данные	Этап	Результат
Сведения о составе, структуре и функционале АСЗИ компании, сведения о доступе к объектам защиты, БДУ ФСТЭК, результаты предыдущего этапа	Возможные объекты воздействия угроз	Наименование и назначение компонентов (инф. ресурсов) АСЗИ компании, которые являются объектами возможного воздействия угроз
		Варианты возможного доступа (видов воздействия) нарушителей информационной безопасности к объектам АСЗИ компании
Особенности организации технологических процессов, сведения о типах внутренних и внешних нарушителей, описание векторов компьютерных атак, содержащиеся в базах данных, сведения о составе, структуре и функционале АСЗИ компании, результаты предыдущего этапа	Оценка возможности реализации угроз и определение их актуальности	Определение источников угроз (модель нарушителя)
		Оценка способов реализации угроз
		Оценка актуальности угроз

Основными объектами защиты информационной безопасности в ООО «Маркетинг с умом» являются:

- информационные ресурсы ограниченного доступа, составляющие персональные данные, коммерческую тайну и иные данные, которые могут быть подвержены несанкционированным воздействиям и нарушению их информационной безопасности, а также общедоступная информация, необходимая для работы «Маркетинг с умом». Примером таких ресурсов может являться информация, находящаяся на серверах в виде файлов, базы данных, носители информации и прочая информация, включая логины, электронные почти и пароли пользователей;

- сотрудники, которые являются разработчиками программного обеспечения (ПО), системными администраторами, администраторами баз данных, операторами и пользователями АСЗИ компании;

- объекты информационной инфраструктуры, включающие в себя системы обработки и анализа информации, технические и программные средства ее обработки, передачи и отображения, каналы связи и телекоммуникации, носители информации, средства и системы защиты

информации, объекты и помещения, в которых находятся средства АСЗИ компании.

- ПО собственной разработки АСЗИ компании;

- процессы обработки и хранения информации в системе, технологии, регламенты и процедуры, использующиеся для сбора, систематизации, накопления, хранения и передачи информации для внутреннего и внешнего взаимодействия системы.

Основными задачами, решаемыми в ходе данной главы, при оценке угроз безопасности информации, являются:

- определение негативных последствий от реализации угроз;

- определение возможных объектов воздействия угроз;

- оценка способов реализации (возникновения) угроз;

- оценка возможности реализации (возникновения) угроз безопасности информации и определение актуальности угроз безопасности информации;

- оценка сценариев реализации угроз безопасности информации в системах и сетях.

В результате моделирования угроз безопасности информации формируется перечень актуальных угроз безопасности информации, реализуемых в информационной инфраструктуре компании.

С целью построения модели угроз целесообразно (с учетом угроз Банка данных угроз безопасности информации) произвести исключение неактуальных угроз для АСЗИ. Перечень исключенных угроз представлен в таблице 5.

Таблица 5 – Перечень исключенных угроз

УГРОЗЫ, СВЯЗАННЫЕ С ГРИД-СИСТЕМАМИ	
УБИ.001	Угроза автоматического распространения вредоносного кода в грид-системе
УБИ.002	Угроза агрегирования данных, передаваемых в грид-системе
УБИ.047	Угроза нарушения работоспособности грид-системы при нетипичной сетевой нагрузке
УБИ.081	Угроза несанкционированного доступа к локальному компьютеру через клиента грид-системы

Продолжение таблицы 5

УГРОЗЫ, СВЯЗАННЫЕ С ГРИД-СИСТЕМАМИ	
УБИ.110	Угроза перегрузки грид-системы вычислительными заданиями
УБИ.147	Угроза распространения несанкционированно повышенных прав на всю грид-систему
УГРОЗЫ, СВЯЗАННЫЕ С ВИРТУАЛЬНЫМИ МАШИНАМИ	
УБИ.010	Угроза выхода процесса за пределы виртуальной машины
УБИ.044	Угроза нарушения изоляции пользовательских данных внутри виртуальной машины
УБИ.046	Угроза нарушения процедуры аутентификации субъектов виртуального информационного взаимодействия
УБИ.048	Угроза нарушения технологии обработки информации путём несанкционированного внесения изменений в образы виртуальных машин
УБИ.052	Угроза невозможности миграции образов виртуальных машин из-за несовместимости аппаратного и программного обеспечения
УБИ.058	Угроза неконтролируемого роста числа виртуальных машин
УБИ.075	Угроза несанкционированного доступа к виртуальным каналам передачи
УБИ.076	Угроза несанкционированного доступа к гипервизору из виртуальной машины и (или) физической сети
УБИ.077	Угроза несанкционированного доступа к данным за пределами зарезервированного адресного пространства, в том числе выделенного под виртуальное аппаратное обеспечение
УБИ.078	Угроза несанкционированного доступа к защищаемым виртуальным машинам из виртуальной и (или) физической сети
УБИ.079	Угроза несанкционированного доступа к защищаемым виртуальным машинам со стороны других виртуальных машин
УБИ.080	Угроза несанкционированного доступа к защищаемым виртуальным устройствам из виртуальной и (или) физической сети
УБИ.108	Угроза ошибки обновления гипервизора
УБИ.119	Угроза перехвата управления гипервизором
УБИ.120	Угроза перехвата управления средой виртуализации
УГРОЗЫ, СВЯЗАННЫЕ С СУПЕРКОМПЬЮТЕРАМИ	
УБИ.029	Угроза использования вычислительных ресурсов суперкомпьютера «паразитными» процессами
УБИ.106	Угроза отказа в обслуживании системой хранения данных суперкомпьютера
УБИ.146	Угроза прямого обращения к памяти вычислительного поля суперкомпьютера
УБИ.161	Угроза чрезмерного использования вычислительных ресурсов суперкомпьютера в ходе интенсивного обмена межпроцессорными сообщениями
УГРОЗЫ, СВЯЗАННЫЕ С ОБЛАЧНЫМИ СИСТЕМАМИ	
УБИ.020	Угроза злоупотребления возможностями, предоставленными потребителям облачных услуг
УБИ.021	Угроза злоупотребления доверием потребителей облачных услуг
УБИ.043	Угроза нарушения доступности облачного сервера
УБИ.054	Угроза недобросовестного исполнения обязательств поставщиками облачных услуг
УБИ.055	Угроза незащищённого администрирования облачных услуг
УБИ.056	Угроза некачественного переноса инфраструктуры в облако
УБИ.064	Угроза некорректной реализации политики лицензирования в облаке

Продолжение таблицы 5

УГРОЗЫ, СВЯЗАННЫЕ С ОБЛАЧНЫМИ СИСТЕМАМИ	
УБИ.065	Угроза неопределённости в распределении ответственности между ролями в облаке
УБИ.066	Угроза неопределённости ответственности за обеспечение безопасности облака
УБИ.070	Угроза непрерывной модернизации облачной инфраструктуры
УБИ.096	Угроза несогласованности политик безопасности элементов облачной инфраструктуры
УБИ.101	Угроза общедоступности облачной инфраструктуры
УБИ.134	Угроза потери доверия к поставщику облачных услуг
УБИ.135	Угроза потери и утечки данных, обрабатываемых в облаке
УБИ.137	Угроза потери управления облачными ресурсами
УБИ.138	Угроза потери управления собственной инфраструктурой при переносе её в облако
УБИ.141	Угроза привязки к поставщику облачных услуг
УБИ.142	Угроза приостановки оказания облачных услуг вследствие технических сбоев
УБИ.164	Угроза распространения состояния «отказ в обслуживании» в облачной инфраструктуре
УГРОЗЫ, СВЯЗАННЫЕ С ДОСУТПОМ В ИНТЕРНЕТ	
УБИ.003	Угроза анализа криптографических алгоритмов и их реализации
УБИ.011	Угроза деавторизации санкционированного клиента беспроводной сети
УБИ.016	Угроза доступа к локальным файлам сервера при помощи URL
УБИ.017	Угроза доступа/перехвата/изменения HTTP cookies
УБИ.019	Угроза заражения DNS-кеша
УБИ.026	Угроза искажения XML-схемы
УБИ.040	Угроза конфликта юрисдикций различных стран
УБИ.041	Угроза межсайтового скриптинга
УБИ.042	Угроза межсайтовой подделки запроса
УБИ.049	Угроза нарушения целостности данных кеша
УБИ.061	Угроза некорректного задания структуры данных транзакции
УБИ.062	Угроза некорректного использования прозрачного прокси-сервера за счёт плагинов браузера
УБИ.073	Угроза несанкционированного доступа к активному и (или) пассивному виртуальному и (или) физическому сетевому оборудованию из физической и (или) виртуальной сети
УБИ.083	Угроза несанкционированного доступа к системе по беспроводным каналам
УБИ.084	Угроза несанкционированного доступа к системе хранения данных из виртуальной и (или) физической сети
УБИ.092	Угроза несанкционированного удалённого внеполосного доступа к аппаратным средствам
УБИ.098	Угроза обнаружения открытых портов и идентификации привязанных к ним сетевых служб
УБИ.099	Угроза обнаружения хостов
УБИ.104	Угроза определения топологии вычислительной сети
УБИ.111	Угроза передачи данных по скрытым каналам
УБИ.125	Угроза подключения к беспроводной сети в обход процедуры аутентификации
УБИ.126	Угроза подмены беспроводного клиента или точки доступа
УБИ.130	Угроза подмены содержимого сетевых ресурсов
УБИ.131	Угроза подмены субъекта сетевого доступа

Продолжение таблицы 5

УГРОЗЫ, СВЯЗАННЫЕ С ДОСУТПОМ В ИНТЕРНЕТ	
УБИ.133	Угроза получения сведений о владельце беспроводного устройства
УБИ.151	Угроза сканирования веб-сервисов, разработанных на основе языка описания WSDL
УБИ.153	Угроза усиления воздействия на вычислительные ресурсы пользователей при помощи сторонних серверов
УБИ.159	Угроза «форсированного веб-браузинга»
УБИ.167	Угроза заражения компьютера при посещении неблагонадёжных сайтов
УБИ.168	Угроза «кражи» учётной записи доступа к сетевым сервисам
УБИ.171	Угроза скрытного включения вычислительного устройства в состав бот-сети.
УБИ.172	Угроза распространения «почтовых червей»
УБИ.173	Угроза «спама» веб-сервера
УБИ.174	Угроза «фарминга»
УБИ.175	Угроза «фишинга»
УБИ.181	Угроза перехвата одноразовых паролей в режиме реального времени
УБИ.186	Угроза внедрения вредоносного кода через рекламу, сервисы и контент
УБИ.190	Угроза внедрения вредоносного кода за счет посещения зараженных сайтов в сети Интернет
УБИ.201	Угроза утечки пользовательских данных при использовании функций автоматического заполнения аутентификационной информации в браузере
УБИ.215	Угроза несанкционированного доступа к системе при помощи сторонних сервисов
УГРОЗЫ, СВЯЗАННЫЕ С BIOS	
УБИ.004	Угроза аппаратного сброса пароля BIOS
УБИ.005	Угроза внедрения вредоносного кода в BIOS
УБИ.009	Угроза восстановления предыдущей уязвимой версии BIOS
УБИ.013	Угроза деструктивного использования декларированного функционала BIOS
УБИ.018	Угроза загрузки нештатной операционной системы
УБИ.024	Угроза изменения режимов работы аппаратных элементов компьютера
УБИ.032	Угроза использования поддельных цифровых подписей BIOS
УБИ.035	Угроза использования слабых криптографических алгоритмов BIOS
УБИ.039	Угроза исчерпания запаса ключей, необходимых для обновления BIOS
УБИ.045	Угроза нарушения изоляции среды исполнения BIOS
УБИ.053	Угроза невозможности управления правами пользователей BIOS
УБИ.072	Угроза несанкционированного выключения или обхода механизма защиты от записи в BIOS
УБИ.087	Угроза несанкционированного использования привилегированных функций BIOS
УБИ.123	Угроза подбора пароля BIOS
УБИ.129	Угроза подмены резервной копии программного обеспечения BIOS
УБИ.144	Угроза программного сброса пароля BIOS
УБИ.150	Угроза сбоя процесса обновления BIOS
УБИ.154	Угроза установки уязвимых версий обновления программного обеспечения BIOS
ИНЫЕ УГРОЗЫ	
УБИ.162	Угроза эксплуатации цифровой подписи программного кода
УБИ.183	Угроза перехвата управления автоматизированной системой управления технологическими процессами

Продолжение таблицы 5

ИНЫЕ УГРОЗЫ	
УБИ.184	Угроза агрегирования данных, обрабатываемых с помощью мобильного устройства
УБИ.194	Угроза несанкционированного использования привилегированных функций мобильного устройства
УБИ.195	Угроза удаленного запуска вредоносного кода в обход механизмов защиты операционной системы
УБИ.196	Угроза контроля вредоносной программой списка приложений, запущенных на мобильном устройстве
УБИ.197	Угроза хищения аутентификационной информации из временных файлов cookie
УБИ.198	Угроза скрытной регистрации вредоносной программой учетных записей администраторов
УБИ.199	Угроза перехвата управления мобильного устройства при использовании виртуальных голосовых ассистентов
УБИ.200	Угроза хищения информации с мобильного устройства при использовании виртуальных голосовых ассистентов
УБИ.202	Угроза несанкционированной установки приложений на мобильные устройства
УБИ.203	Угроза утечки информации с неподключенных к сети Интернет компьютеров
УБИ.204	Угроза несанкционированного изменения вредоносной программой значений параметров программируемых логических контроллеров
УБИ.206	Угроза отказа в работе оборудования из-за изменения геолокационной информации о нем
УБИ.207	Угроза несанкционированного доступа к параметрам настройки оборудования за счет использования «мастер-кодов»
УБИ.208	Угроза нецелевого использования вычислительных ресурсов средства вычислительной техники
УБИ.210	Угроза нарушения работы информационной системы, вызванного обновлением используемого в ней программного обеспечения
УБИ.213	Угроза обхода многофакторной аутентификации
УБИ.216	Угроза получения несанкционированного доступа к приложениям, установленным на Smart-картах

Назначение документа

Документ определяет порядок и содержание работ по определению угроз безопасности информации, реализация (возникновение) которых возможна в информационной системе маркетинговой компании.

Область действия документа

Документ применяется для определения угроз безопасности информации, реализация (возникновение) которых возможна в системах и сетях, отнесенных к информационным системам персональных данных.

Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз

При проведении оценки угроз безопасности информации и разработке модели угроз безопасности персональных данных в АСЗИ использовались действующие нормативные правовые акты, методические документы и национальные стандарты Российской Федерации, регламентирующие порядок защиты персональных данных и построения систем защиты информации:

– Федеральный закон Российской Федерации № 152-ФЗ от 27.07.2006. «О персональных данных».

– Постановление Правительства Российской Федерации № 1119 от 01.11.2012. «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».

– Приказ ФСТЭК России № 21 от 18.02.2013. «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных».

– Методические рекомендации ФСТЭК России от 14.02.2008. «По определению актуальных угроз безопасности персональных данных при их обработке в информационных системах персональных данных».

– Федеральный закон Российской Федерации № 98-ФЗ от 29.07.2004. «О коммерческой тайне».

– ГОСТ Р 51583–2014. «Защита информации. Порядок создания автоматизированных систем в защищённом исполнении».

– ГОСТ Р 59793-2021. «Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания».

– ГОСТ 34.602–2020. «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание».

– ГОСТ Р 56939–2016. «Информационная технология. Методы и средства обеспечения безопасности. Оценка уязвимостей информационной системы».

– Приказ ФСБ России № 378 от 10.07.2014. «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их криптографической защите».

Наименование обладателя информации, заказчика, оператора систем и сетей

ООО «Маркетинг с умом».

Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) систем и сетей

Отдел службы защиты информации – администратор информационной безопасности.

Администрация маркетинговой компании – генеральный директор.

Наименование организации, привлекаемой для разработки модели угроз безопасности информации (при наличии)

Отсутствует, разработка модели произведена собственными силами.

Описание систем и сетей и их характеристика как объектов защиты

Наименование систем и сетей, для которых разработана модель угроз безопасности информации

Объектом защиты является автоматизированная система в защищенном исполнении для учета кадров компании.

Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных

Для определения уровня защищенности воспользуемся таблицей 6, построенной на основании положений Постановления Правительства РФ от 01.11.2012 N 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».

Уровень защищенности АСЗИ – четвертый (основание: Акт комиссии по определению уровня защищенности персональных данных в АСЗИ № 02 от 12.07.2025).

Таблица 6 – Данные для определения УЗ ПДн в АСЗИ

Тип АСЗИ	Категории субъектов	Количество субъектов	Тип актуальных угроз		
			1 тип (НДВ в СПО)	2 тип (НДВ в ППО)	3 тип (нет НДВ)
АСЗИ-С (специальные)	Не сотрудников	Более 100 000	УЗ 1	УЗ 1	УЗ 2
		Менее 100 000	УЗ 1	УЗ 2	УЗ 3
	Сотрудников	Любое	УЗ 1	УЗ 2	УЗ 3
АСЗИ-Б (биометрические)	Любых	Любое	УЗ 1	УЗ 2	УЗ 3
АСЗИ-И (иные)	Не сотрудников	Более 100 000	УЗ 1	УЗ 2	УЗ 3
		Менее 100 000	УЗ 1	УЗ 3	УЗ 4
	Сотрудников	Любое	УЗ 1	УЗ 3	УЗ 4
АСЗИ-О (общедоступные)	Не сотрудников	Более 100 000	УЗ 2	УЗ 2	УЗ 4
		Менее 100 000	УЗ 2	УЗ 3	УЗ 4
	Сотрудников	Любое	УЗ 2	УЗ 3	УЗ 4

Нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и функционируют системы и сети

При разработке, внедрении и эксплуатации системы учитываются следующие нормативные правовые акты:

- Федеральный закон № 149 от 27.07.2006 "Об информации, информационных технологиях и о защите информации",

- Федеральный закон № 126 от 07.07.2003 "О связи",

- Федеральный закон № 152 от 27.07.2006 "О персональных данных",

- Постановление Правительства Российской Федерации № 1119 от 01.11.2012. «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».

Назначение, задачи (функции) систем и сетей, состав обрабатываемой информации и ее правовой режим

Назначение: АСЗИ предназначена для обработки и хранения информации о сотрудниках компании для учета рабочего времени, начисления заработной платы, формирования необходимой отчетности в контролируемые органы.

Персональные данные работников ООО «Маркетинг с умом» обрабатываются с целью:

- ведения учета рабочего времени;
- ведения расчетов заработной платы и премий;
- ведения бухгалтерского учета;
- осуществления выплат и передачи необходимой информации в уполномоченные органы власти, такие как ФНС, ФСС, ПФР.

В АСЗИ обрабатываются следующие персональные данные:

- фамилия, имя, отчество работника;
- данные документа, удостоверяющего личность сотрудника (номер, серия, кем и когда выдан);
- дата рождения;
- адрес регистрация и фактического проживания;
- реквизиты ИНН;
- реквизиты полиса обязательного медицинского страхования и индивидуального лицевого счета в Пенсионном фонде России;
- реквизиты банковской карты работника;
- сведения о доходе работника и дополнительных начислениях;

Вышеперечисленные персональные данные обрабатываются в соответствии с Трудовым и Налоговым кодексом РФ, Федеральным закон «О

бухгалтерском учете» от 06.12.2011 N 402-ФЗ, согласием работника на обработку ПДн.

Основные процессы (бизнес-процессы) обладателя информации, оператора, для обеспечения которых создаются (функционируют) системы и сети

В качестве основных процессов, для которых создана АСЗИ, выступает учет рабочего времени и выплата заработной платы работникам, для выполнения их служебных обязанностей в рамках жизнедеятельности и обеспечения бесперебойной работы компании.

Состав и архитектура систем и сетей, в том числе интерфейсы и взаимосвязи компонентов систем и сетей

АСЗИ представляет собой корпоративную систему, обеспечивающую внесение, изменение, обработку и хранение персональных данных сотрудников, а также автоматизацию бизнес-процессов взаимодействия с между отделами.

АСЗИ включает следующие взаимосвязанные подсистемы, модули и технические средства:

– Подсистема защиты информации;

– Подсистема регистрации заявок;

– Подсистема обработки документов;

– Подсистема отчетности;

– БД АСЗИ.

Взаимосвязь компонентов обозначена на рисунке 1. Подсистема защиты информации (ЗИ) обозначена на рисунке 2.

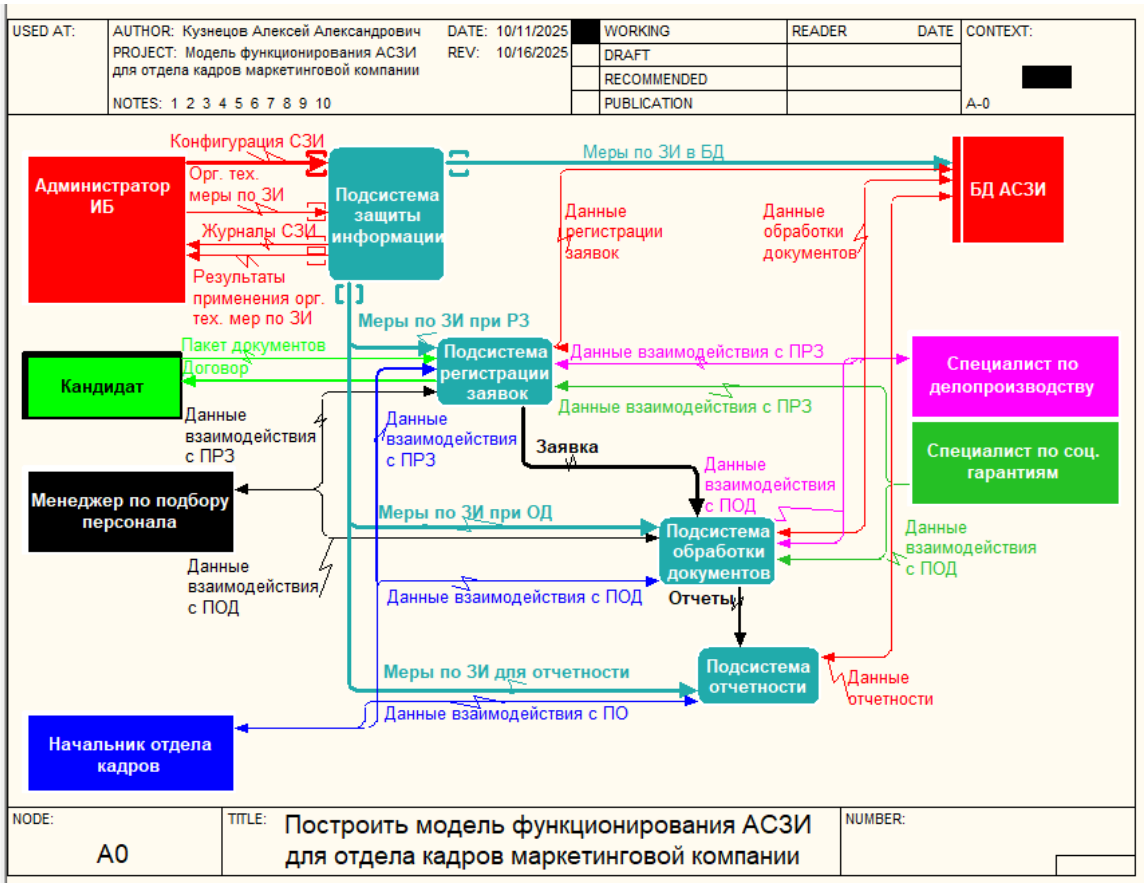


Рисунок 1 - Диаграмма декомпозиции контекстной диаграммы модели функционирования АСЗИ

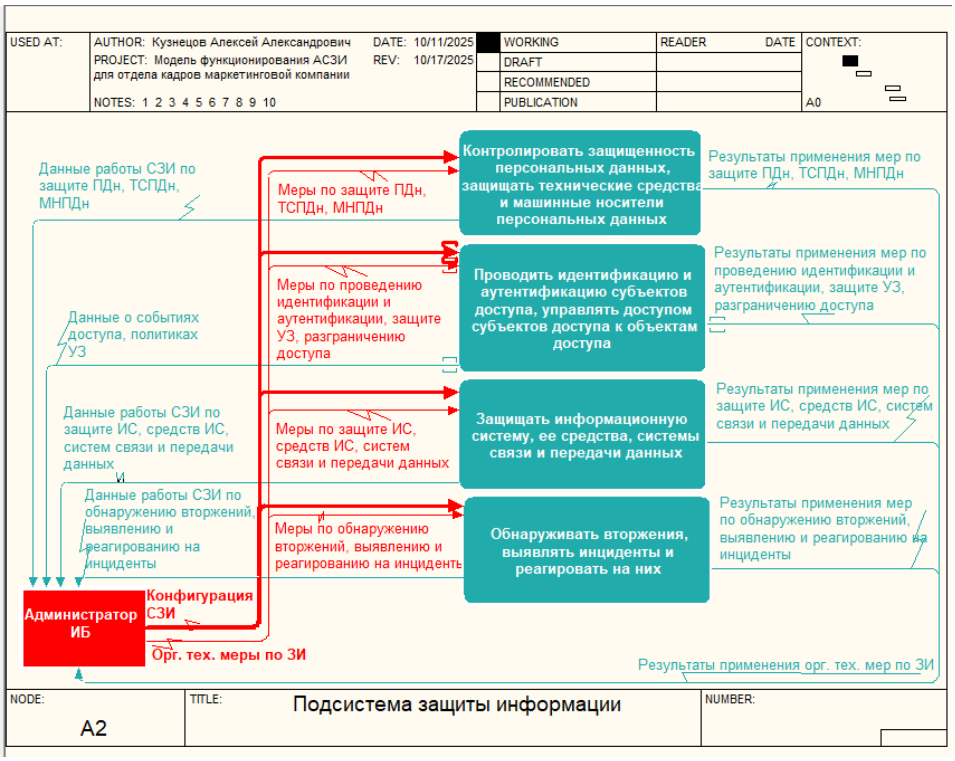


Рисунок 2 - Диаграмма декомпозиции подсистемы ЗИ

Все пользователи имеют собственные роли и полномочия. Список пользователей и их типов доступа представлен в виде матрицы доступа в таблице 7.

Таблица 7 – Матрица доступа к АСЗИ

Группа пользователей	Уровень доступа к АСЗИ	Полномочия	Сотрудники
Системный администратор	Обладает полной информацией о системном и прикладном программном обеспечении АСЗИ. Обладает полной информацией о технических средствах и конфигурации АСЗИ. Имеет доступ ко всем техническим средствам обработки информации и даннным. Обладает правами конфигурирования и административной настройки технических средств АСЗИ.	- хранение - систематизация - сбор - накопление	Сотрудники отдела администрирования, допущенные к работе с АСЗИ: Андреев И.А. Калашников В.В. Наливкин О.Л.
Программист, специалист по базам данных	Обладает правами администратора АСЗИ. Обладает полной информацией об АСЗИ. Имеет доступ к средствам защиты информации и протоколирования и к части ключевых элементов АСЗИ Не имеет прав доступа к конфигурированию технических средств сети за исключением контрольных	- сбор - систематизация - накопление - хранение - уничтожение - уточнение	Сотрудники технического отдела: Баневич И.О. Смирнов В.Д. Ломов О.К.
Операторы АСЗИ с правами чтения и записи	Обладают всеми необходимыми правами и полномочиями, позволяющие осуществлять запись, удаление, изменение в базе данных	- сбор - накопление - хранение - уничтожение - уточнение - использование - распространение	Сотрудники бухгалтерии: Козлова И.О. Соломова В.Д. Карась К.К. Сотрудники отдела кадров: Доброва Н.Н. Вилкова Д.Л. Никонова П.П.

Описание внешних интерфейсов и взаимодействий систем и сетей с пользователями (в том числе посредством машинных носителей информации, средств ввода-вывода, веб-приложений), иными системами и сетями, обеспечивающими системами, в том числе с сетью «Интернет» представлено в таблице 8.

Таблица 8 – Описание взаимодействия пользователей и системы

№ п/п	Описание входа внешних пользователей	Описание входа внутренних пользователей	Описание выгрузки информации из АСЗИ на машинные носители	Описание работы с АСЗИ с помощью веб-приложений	Взаимосвязь с другими системами/БД	Взаимодействие АСЗИ с сетью Интернет
1	Отсутствует	По логину и паролю для каждого отдельного работника (существует политика паролей)	Выгрузка разрешена с указанием прямого или второстепенного места выгрузки и разрешения начальника отдела	Интерфейс АСЗИ реализован в виде веб-приложения на основе веб-сервера Apache	Настроено взаимодействие с разработанной собственными силами системой мониторинга выполнения показателей (из АСЗИ идет подгрузка ПДн в систему мониторинга – в рамках одной ЛВС)	Имеется, для обновления АСЗИ, для обеспечения удаленного доступа работников

Структурная схема АСЗИ

Логическая схема сети АСЗИ представлена на рисунке 3.

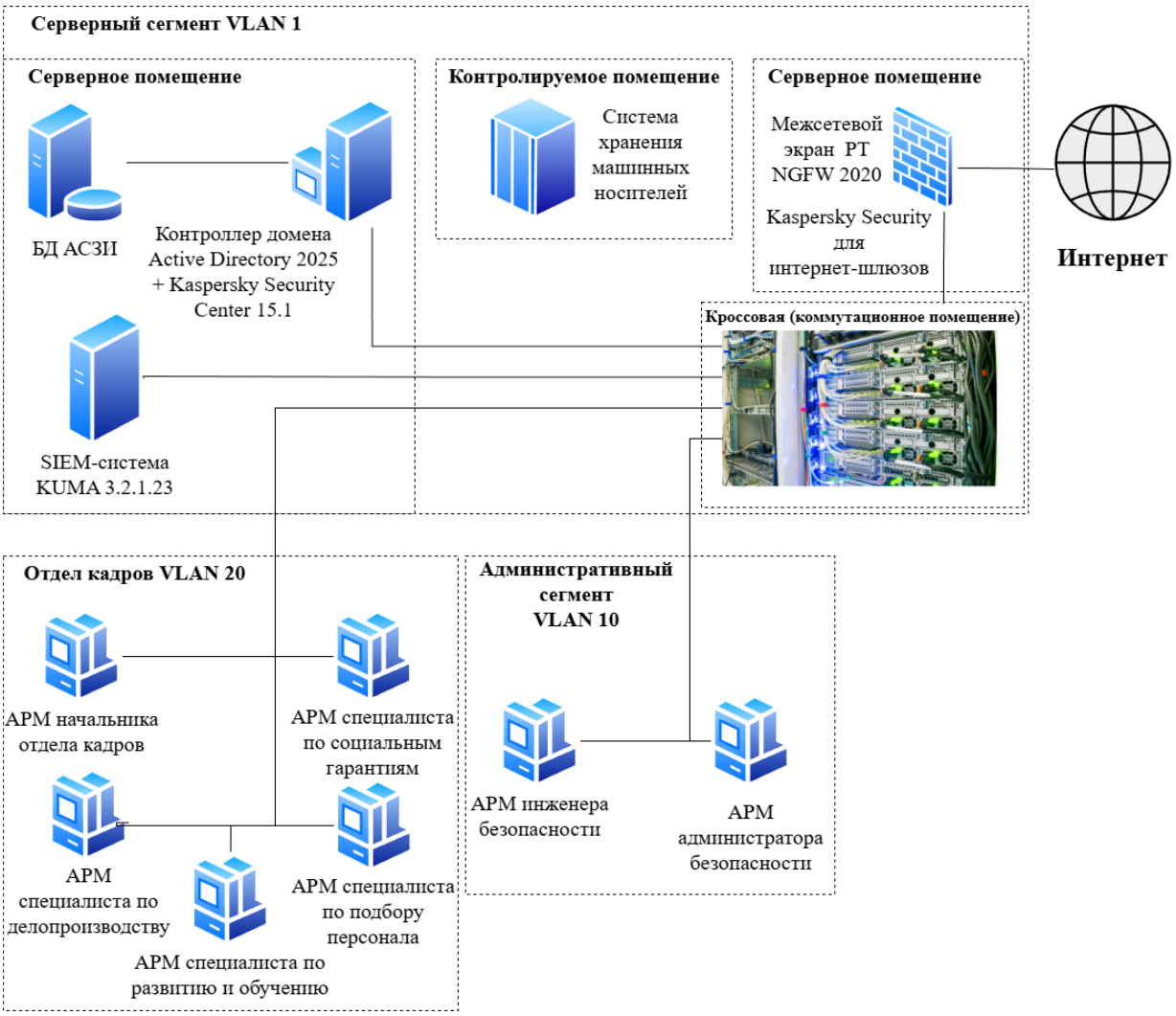


Рисунок 3 – Логическая схема сети АСЗИ

Сеть построена по принципу клиент–серверной архитектуры с разграничением прав доступа и использованием средств защиты информации для обеспечения безопасного взаимодействия между компонентами системы.

В состав сети входят следующие элементы:

– БД АСЗИ — центральное хранилище персональных данных сотрудников, расположенное в контролируемой зоне;

– Контроллер домена Active Directory 2025 — обеспечивает централизованную аутентификацию пользователей, управление и разграничение доступа, поддержку политик и правил, взаимодействие между подсистемами. Защищен Kaspersky Endpoint Security для Windows версии 12.8.0.505 (сертификат соответствия №4068 от 22.01.2019). Также на сервере установлено СЗИ Kaspersky Security Center версии 15.1.0.20748 (сертификат

соответствия №3155 от 06.05.2014), обеспечивающее возможность контролировать и настраивать безопасность корпоративной сети, управлять установленными приложениями, политиками, задачами и отчетами из единой консоли;

– SIEM-система Kaspersky Unified Monitoring and Analysis Platform (KUMA) версии 3.2.1.23 (сертификат соответствия №4455 от 28.09.2021) обеспечивает централизованный сбор, анализ, корреляцию событий безопасности, и предоставляет возможность реагирования на инциденты;

– Межсетевой экран PT NGFW 2020 (сертификат соответствия №4877 от 19.11.2024) обеспечивает маршрутизацию и анализ трафика, трансляцию сетевых адресов, контроль приложений и пользователей, блокирование ВПО и атак на корпоративную сеть. ПО Kaspersky Security для интернет-шлюзов обеспечивает многоуровневую защиту интернет-шлюза от новейших интернет-угроз, блокирует доступ к вредоносным ресурсам и контролирует веб-активность;

– Кроссовая (коммутационная комната) — защищенное помещение, содержащее в себе стойки с коммутационным оборудованием. Используются коммутаторы отечественного поставщика Eltex 10G MES5332A, обеспечивающие сегментацию сети по отделам. Помещение содержит камеры видеонаблюдения для предотвращения НСД;

– Система хранения машинных носителей предназначена для хранения жестких дисков, твердотельных накопителей с информацией. Доступ осуществляется с использованием СКУД. Помещение содержит камеры видеонаблюдения для предотвращения НСД;

– Автоматизированные рабочие места (АРМ) пользователей — рабочие станции менеджеров, специалистов и начальников отделов, подключённые с помощью патч-кордов к коммутаторам в кроссовой. Защищены с помощью Kaspersky Endpoint Security для Windows версии 12.8.0.505 (сертификат соответствия №4068 от 22.01.2019), а также обладают модулями доверенной загрузки;

– АРМ администратора безопасности — специализированное рабочее место с расширенными правами для администрирования системы и контроля безопасности;

– Интернет — доступ во внешнюю сеть через защищённые каналы с аутентификацией и шифрованием трафика с целью обновления ПО и актуализации информационных баз установленных СЗИ.

Описание групп внешних и внутренних нарушителей

Описание групп внешних и внутренних потенциальных нарушителей для АСЗИ, а также определение их актуальности представлено в таблице 9.

Таблица 9 – Описание групп внешних и внутренних нарушителей для объекта АСЗИ

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
1	СС иностранных государств	Внешний	Данный тип нарушителя не заинтересован в воздействии на АСЗИ, принадлежащую ООО «Маркетинг с умом», т.к. это не соответствует его целям, описанным в Приложение 6 к Методике оценки угроз безопасности информации ФСТЭК	Н4	Не целесообразно к рассмотрению, в соответствии с обоснованием, данным в столбце 4 настоящей таблицы	Не целесообразно к рассмотрению, в соответствии с обоснованием, данным в столбце 4 настоящей таблицы	Не актуален
2	Террористические, экстремистские группировки	Внешний	Данный тип нарушителя не заинтересован в воздействии на АСЗИ, принадлежащую ООО «Маркетинг с умом», т.к. это не соответствует его целям, описанным в Приложение 6 к Методике оценки угроз безопасности информации ФСТЭК	Н3	Не целесообразно к рассмотрению, в соответствии с обоснованием, данным в столбце 4 настоящей таблицы	Не целесообразно к рассмотрению, в соответствии с обоснованием, данным в столбце 4 настоящей таблицы	Не актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
3	Преступные группы (криминальные структуры)	Внешний	Получение финансовой или иной материальной выгоды	H2	Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет Фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	T1, T2, T3, T4, T5, T6, T9, T10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
4	Отдельные физические лица (хакеры)	Внешний	Получение финансовой или иной материальной выгоды	Н1	Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Т1, Т2, Т4, Т6, Т10	Актуален
5	Конкурирующие организации	Внешний	Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды	Н2	Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Т1, Т2, Т3, Т4, Т5, Т6, Т9, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
6	Разработчики программных, программно-аппаратных средств	Внутренний	Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия	Н3	Имеет возможность приобретать информацию об уязвимостях, размещаемую на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность приобретать дорогостоящие средства и инструменты для реализации угроз, размещаемые на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность самостоятельно разрабатывать средства, необходимые для реализации угроз (атак), реализовывать угрозы с использованием данных средств. Имеет возможность получения доступа к встраиваемому программному обеспечению аппаратных платформ, системному и прикладному программному обеспечению, телекоммуникационному оборудованию и другим программно-аппаратным средствам для проведения их анализа. Обладает знаниями и практическими навыками проведения анализа программного кода для получения информации об уязвимостях.	Т1, Т2, Т3, Т4, Т5, Т6, Т7, Т8, Т9, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
7	Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем	Внешний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ	Н1	Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Т1, Т2, Т4, Т6, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
8	Поставщики вычислительных услуг, услуг связи	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ	Н2	Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Т1, Т2, Т3, Т4, Т5, Т6, Т9, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
9	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ	H2	Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	T1, T2, T3, T4, T5, T6, T9, T10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
10	Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия	Н1	Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Т1, Т2, Т4, Т6, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
11	Авторизованные пользователи систем и сетей	Внутренний	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия	Н1	Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Т1, Т2, Т4, Т6, Т10	Актуален

Продолжение таблицы 9

№,п/п	Вид нарушителя	Категория возможного пользователя/нарушителя	Возможные цели реализации угроз безопасности информации	Уровень возможностей нарушителя	Возможности нарушителя	Возможные к применению тактики	Гипотетическая актуальность
12	Системные администраторы и администраторы безопасности	Внутренний	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия	Н2	Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Т1, Т2, Т3, Т4, Т5, Т6, Т9, Т10	Актуален
13	Бывшие работники (пользователи)	Внешний	Получение финансовой или иной материальной выгоды. Месть за ранее совершенные действия	Н1	Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Т1, Т2, Т4, Т6, Т10	Актуален

Возможные негативные последствия, объекты воздействия, источники и способы реализации угроз

С целью оптимизации подхода к определению возможных негативных последствий для объектов от реализации угроз целесообразно объединить пункты «3. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации», «4. Возможные объекты воздействия угроз безопасности информации», «5. Источники угроз безопасности информации», «6. Способы реализации (возникновения) угроз безопасности информации», рассмотрев в таблице следующие пункты:

- описание видов рисков (ущербов), актуальных для обладателя информации, оператора, которые могут наступить от нарушения или прекращения основных процессов (столбец 3);

- описание негативных последствий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к возникновению рисков (ущерба) (столбец 3);

- наименования и назначение компонентов систем и сетей, которые непосредственно участвуют в обработке и хранении защищаемой информации, или обеспечивают реализацию основных процессов обладателя информации, оператора (столбец 2);

- описание видов воздействия на компоненты систем и сетей, реализация которых нарушителем может привести к негативным последствиям (столбец 3);

- характеристику нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации (столбец 2);

- категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации (столбец 2);

- описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре систем и сетей (столбец 2);

- описание способов реализации (возникновения) угроз безопасности информации, которые могут быть использованы нарушителями разных видов и категорий (столбец 6);

- описание интерфейсов объектов воздействия, доступных для использования нарушителями способов реализации угроз безопасности информации (столбец 6).

Таблица 10 – Описание внешних и внутренних нарушителей для АСЗИ

№, п/п	Назначение объекта	Вид/ категория нарушителя/возможности нарушителя	Виды воздействия/ негативные последствия/ виды риска	Соотнесение с угрозами	Цели реализации угроз	Описание способов реализации угроз/ описание интерфейсов объектов воздействия
1	2	3	4	5	6	7
1	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Разработчики программных, программно-аппаратных средств/ внутренний/ Имеет возможность приобретать информацию об уязвимостях, размещаемую на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность приобретать дорогостоящие средства и инструменты для реализации угроз, размещаемые на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность самостоятельно разрабатывать средства, необходимые для реализации угроз (атак), реализовывать угрозы с использованием данных средств.	Вид воздействия – Несанкционированная модификация, подмена, искажение защищаемой информации, системных, конфигурационных, иных служебных данных (нарушение целостности) (конкретно-Модификация всей БД АСЗИ)	Возможно при реализации угроз УБИ 089, 091, 152, 158, 165, 179, 187, 214	Непреднамеренные, неосторожные или неквалифицированные действия	Внедрение вредоносного программного обеспечения/ Доступ через локальную вычислительную сеть организации Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя/ Съемные машинные носители информации, подключаемые к АРМ пользователя Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя/ Сетевые интерфейсы коммутатора сети, где расположен веб-сервер

Продолжение таблицы 10

1	2	3	4	5	6	7
1		Имеет возможность получения доступа к встраиваемому программному обеспечению аппаратных платформ, системному и прикладному программному обеспечению, телекоммуникационному оборудованию и другим программно-аппаратным средствам для проведения их анализа. Обладает знаниями и практическими навыками проведения анализа программного кода для получения информации об уязвимостях. Обладает высокими знаниями и практическими навыками о функционировании систем и сетей, операционных систем, а также имеет глубокое понимание защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах. Имеет возможность реализовывать угрозы безопасности информации в составе группы лиц.	Негативные последствия: Подмена данных работников организации, платежных реквизитов, отчетности. Виды риска: У2: 2.1, 2.4, 2.6, 2.8, 2.18			

Продолжение таблицы 10

1	2	3	4	5	6	7
2	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Преступные группы (криминальные структуры)/внешний/ Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет Фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Вид воздействия – Несанкционированная модификация, подмена, искажение защищаемой информации, системных, конфигурационных, иных служебных данных (нарушение целостности) (конкретно- Модификация всей БД АСЗИ) Утечка (перехват) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (конкретно – кража ПД из Базы данных АСЗИ) Негативные последствия: Подмена или кража данных работников организации, платежных реквизитов, отчетности. Дискредитация работников, нарушение конфиденциальности ПДн Виды риска: У1: 1.9, 1.11 У2: 2.1, 2.14, 2.11, 2.15, 2.25	Возможно, при реализации угроз УБИ 003, 007, 016, 037,030,201,190,139, 080, 122, 143, 187,189, 140	Получение финансовой или иной материальной выгоды. Желание самореализации (подтверждение статуса)	Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя/ Съемные машинные носители информации, подключаемые к АРМ пользователя Использование уязвимостей кода программного обеспечени веб-сервера Использование уязвимостей конфигурации системы управления базами данных/ Пользовательский веб-интерфейс доступа к базе данных информационной системы Подкуп сотрудника компании

Продолжение таблицы 10

1	2	3	4	5	6	7
3	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Отдельные физические лица (хакеры)/внешний/ Обладает базовыми компьютерными знаниями на уровне пользователя.Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Вид воздействия – утечка (перехват) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (утечка ПДн из БД) Несанкционированный доступ к компонентам, защищаемой информации, системным, конфигурационным, иным служебным данным (доступ к АС, доступ к БД) Несанкционированное использование вычислительных ресурсов систем и сетей в интересах решения несвойственных им задач Негативные последствия: Дискредитация работников, Нарушение штатного режима функционирования АС управления и управляемого объекта и/или процесса. Необходимость дополнительных (незапланированных) затрат на восстановление деятельности. Публикация недостоверной информации на веб-ресурсах организации Виды риска: У1: 1.9, 1.11 У2: 2.8, 2.6, 2.12, 2.14, 2.25, 2.22, 2.24, 2.23	Возможно, при реализации угроз УБИ 006, 008, 034, 041, 083, 084, 100, 152, 178, 191, 140	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса)	Доступ через ЛВС организации/ Внедрение вредоносного программного обеспечения. Съемные машинные носители информации, подключаемые к АРМ пользователя/ Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя. Веб-интерфейс пользователя веб-сайта АСЗИ/ Использование уязвимостей кода программного обеспечения веб-сервера. Использование социальной инженерии для НСД к АСЗИ. Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя/ Сетевые интерфейсы коммутатора сети, где расположен веб-сервер

Продолжение таблицы 10

1	2	3	4	5	6	7
4	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Конкурирующие организации/внешние/ Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Вид воздействия – утечка (перехват) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (утечка ПДн из БД) Нарушение функционирования (работоспособности) программно-аппаратных средств обработки, передачи и хранения информации Негативные последствия: Дискредитация или перманивание работников, Необходимость дополнительных (незапланированных) затрат на закупку товаров, работ или услуг (в том числе закупка программного обеспечения, технических средств, вышедших из строя, замена, настройка, ремонт указанных средств, Потеря конкурентного преимущества Виды риска: У1: 1.9, 1.11 У2: 2.3, 2.5, 2.9, 2.10, 2.12, 2.14, 2.18, 2.11	Возможно, при реализации угроз УБИ 030, 036, 042, 073, 080, 122, 139, 187, 190, 215, 140	Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды. Перемагничивание сотрудников	Доступ через ЛВС организации/ Внедрение вредоносного программного обеспечения. Съемные машинные носители информации, подключаемые к АРМ пользователя/ Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя. Веб-интерфейс пользователя веб-сайта АСЗИ/ Использование уязвимостей кода программного обеспечения веб-сервера. Использование социальной инженерии для НСД к АСЗИ. Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя/ Сетевые интерфейсы коммутатора сети, где расположен веб-сервер. Пользовательский веб-интерфейс доступа к базе данных информационной системы/Использование уязвимостей конфигурации системы управления базами данных

Продолжение таблицы 10

1	2	3	4	5	6	7
5	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)/внутренний/Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации	Вид воздействия – утечка (перехват) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (утечка ПДн из БД) Нарушение функционирования (работоспособности) программно-аппаратных средств обработки, передачи и хранения информации отказ в обслуживании компонентов (нарушение доступности) Негативные последствия: Выведение из строя средств обработки и хранения информации, кража (утечка) ПДн Виды риска: У1: 1.9, 1.11 У2: 2.6, 2.8, 2.11, 2.14, 2.21, 2.9, 2.18, 2.17	Возможно, при реализации угроз УБИ 023, 030, 078, 084, 090, 100, 152, 178, 088, 140	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия	Доступ через локальную вычислительную сеть организации/ Внедрение вредоносного программного обеспечения Съемные машинные носители информации, подключаемые к АРМ пользователя/ Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя Технические средства обработки и хранения информации/ непреднамеренное физическое воздействие в результате неосторожных или неквалифицированных действий

Продолжение таблицы 10

1	2	3	4	5	6	7
6	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Авторизованные пользователи систем и сетей/внутренний/ Обладает базовыми компьютерными знаниями на уровне пользователя. Имеет возможность использовать только известные уязвимости, скрипты и инструменты, а также средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации.	Вид воздействия – утечка (перехват, кража) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (утечка(кража) ПДн из БД) Нарушение функционирования (работоспособности) программно-аппаратных средств обработки, передачи и хранения информации отказ в обслуживании компонентов (нарушение доступности) несанкционированная модификация, подмена, искажение защищаемых данных (нарушение целостности) Негативные последствия: Выведение из строя средств обработки и хранения информации, кража (утечка) ПДн, случайная модификация или удаление данных Виды риска: У1: 1.9, 1.11 У2: 2.6, 2.8, 2.11, 2.14, 2.21, 2.9, 2.18, 2.17, 2.20	Возможно, при реализации угроз УБИ 012, 023, 030, 034, 078, 084, 090, 100, 178, 192, 191, 088	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия	Локальная вычислительная сеть организации/Ошибочные действия в ходе настройки АРМ главного бухгалтера Технические средства обработки и хранения информации/ непреднамеренное физическое воздействие в результате неосторожных или неквалифицированных действий, Утеря аутентификационных данных или машинных носителей

Продолжение таблицы 10

1	2	3	4	5	6	7
7	АСЗИ предназначена для обработки информации о работниках учреждения с целью учета рабочего времени, начисления заработной платы, формирования отчётности в контролирующие органы	Системные администраторы и администраторы безопасности/внутренний/ Имеет возможность использовать средства реализации угроз, свободно распространяемые в сети «Интернет» и разработанные другими лицами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей. Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации.	Вид воздействия – утечка (перехват, кража) конфиденциальной информации или отдельных данных (нарушение конфиденциальности) (утечка(кража) ПДн из БД) Нарушение функционирования (работоспособности) программно-аппаратных средств обработки, передачи и хранения информации отказ в обслуживании компонентов (нарушение доступности) несанкционированная модификация, подмена, искажение защищаемой информации, системных, конфигурационных, иных служебных данных (нарушение целостности) Отказ в обслуживании компонентов (нарушение доступности)	Возможно, при реализации угроз УБИ 010, 063, 068, 073, 080, 122, 187, 188, 212, 217	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия	Локальная вычислительная сеть организации/ Ошибочные действия в ходе настройки АРМ, серверов, средств защиты информации Сетевые интерфейсы коммутатора сети, где расположен веб-сервер/ Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя Пользовательский веб-интерфейс доступа к базе данных информационной системы/ Использование уязвимостей конфигурации системы управления базами данных Съемные машинные носители информации, содержащие аутентификационную информацию Извлечение аутентификационной информации из постоянной памяти носителя (инвазивный метод)

Продолжение таблицы 10

1	2	3	4	5	6	7
7		Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах.	Негативные последствия: Выведение из строя средств обработки и хранения информации, кража (утечка) ПДн, случайная модификация или удаление данных, отказ в обслуживании компонентов АСЗИ Виды риска: У1: 1.9, 1.11 У2: 2.5, 2.6, 2.8, 2.11, 2.14, 2.21, 2.9, 2.18, 2.17, 2.20, 2.15			

Актуальные угрозы безопасности информации

Рассмотренные угрозы из БДУ ФСТЭК приведены в таблице 11. Всего будет рассмотрена одна угроза:

УБИ.088 - Угроза несанкционированного копирования защищаемой информации.

Таблица 11 – Актуальные угрозы ИБ

Перечень возможных (вероятных) угроз безопасности информации	Тактики, применения которых достаточно для реализации угрозы/Описание возможных сценариев реализации угроз безопасности информации	Нарушитель, способный на реализацию угрозы	Необходимый набор средств/мер для нейтрализации угрозы/нарушителя	Имеющийся набор средств/мер для нейтрализации угрозы/нарушителя	Вывод об актуальности угрозы
1	2	3	4	5	6
088 Угроза несанкционированного копирования защищаемой информации	Т2 Получение первоначального доступа к компонентам систем и сетей Т2.1 Использование внешних сервисов организации в сетях публичного доступа (Интернет) Т2.2 Использование устройств, датчиков, систем, расположенных на периметре или вне периметра физической защиты объекта Т2.3 Эксплуатация уязвимостей сетевого оборудования и средств защиты вычислительных сетей Т2.4 Использование ошибок конфигурации сетевого оборудования и средств защиты Т2.5 Эксплуатация уязвимостей компонентов систем и сетей при удаленной или локальной атаке Т2.6 Использование недокументированных возможностей программного обеспечения Т2.7 Использование в системе внешних носителей информации Т2.8 Использование методов социальной инженерии, в том числе фишинга Т2.9 Несанкционированное подключение внешних устройств Т2.10 Несанкционированный доступ путем подбора учетных данных сотрудника Т2.11 Несанкционированный доступ путем компрометации учетных данных сотрудника организации Т2.12 Использование доступа к системам и сетям, предоставленного сторонним организациям	Высокий риск: Системные администраторы (7) - имеют максимальные привилегии доступа к данным сотрудников и серверным помещениям Авторизованные пользователи (6) - сотрудники отдела кадров, имеющие прямой доступ к персональным данным	Разработка и внедрение Политики разграничения доступа к информации. Внедрение Парольной политики организации. Регулярное проведение внутреннего аудита и тестирования на проникновение с использованием сертифицированных сканеров уязвимостей. Разработка и внедрение Инструкции пользователя АСЗИ, включающей раздел по противодействию методам социальной инженерии.	В данный момент в «Маркетинг с умом» имеется сертифицированное ФСТЭК системное, антивирусное и прикладное ПО, а также межсетевой экран Dionis DPS. Парольная политика отсутствует.	Актуальна

Продолжение таблицы 11

1	2	3	4	5	6
	Т2.13 Реализация атаки типа "человек посередине" Т6 Повышение привилегий по доступу к компонентам систем и сетей Т6.1 Получение данных для аутентификации и авторизации от имени привилегированной учетной записи Т6.2 Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи Т6.3 Эксплуатация уязвимостей ПО к повышению привилегий Т6.4 Эксплуатация уязвимостей механизма имперсонации Т6.5 Манипуляции с идентификатором сессии, токеном доступа Т6.6 Обход политики ограничения пользовательских учетных записей Т6.7 Использование уязвимостей конфигурации системы, служб и приложений Т6.8 Эксплуатация уязвимостей, связанных с отдельным контролем доступа к ресурсам Т6.9 Эксплуатация уязвимостей средств ограничения среды исполнения Т9 Сбор и вывод из системы или сети информации, необходимой для дальнейших действий Т9.1 Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления	Средний риск: Разработчики (1) - могли оставить скрытые механизмы доступа к системе Обслуживающий персонал (5) - имеют физический доступ к оборудованию	Внедрение сертифицированной системы DLP (Data Loss Prevention) для мониторинга и блокирования попыток несанкционированного копирования защищаемой информации. Использование сертифицированных систем обнаружения и предотвращения вторжений (IDS/IPS) для мониторинга сетевой активности в реальном времени. Использование сертифицированного антивирусного ПО с функциями поведенческого анализа и защиты от целевых атак на всех компонентах АСЗИ.		

Продолжение таблицы 11

1	2	3	4	5	6
	Т9.2 Доступ к системе для сбора информации и вывод информации через штатные средства удаленного доступа Т9.3 Вывод информации на хорошо известные порты на внешних серверах Т9.4 Вывод информации на нестандартные порты на внешних серверах Т9.5 Отправка данных по известным протоколам управления и передачи данных Т9.6 Отправка данных по собственным протоколам Т9.7 Проксирование трафика передачи данных для маскировки подозрительной сетевой активности Т9.8 Туннелирование трафика передачи данных через VPN Т9.9 Туннелирование трафика управления в поля заполнения служебных протоколов Т9.10 Вывод информации через съемные носители Т9.11 Отправка данных через альтернативную среду передачи данных Т9.12 Шифрование выводимой информации, использование стеганографии Т9.13 Вывод информации через предоставление доступа к файловым хранилищам и базам данных Т9.14 Вывод информации путем размещения сообщений или файлов на публичных ресурсах	Низкий риск: Внешние нарушители (2,3,4) - ограничены из-за изолированности системы, но возможны через инсайдеров	Внедрение системы мониторинга и аудита действий пользователей с регистрацией всех операций с персональными данными сотрудников. Использование средств криптографической защиты информации для шифрования данных на серверах БД и рабочих станциях. Внедрение системы контроля доступа к съемным носителям информации с разграничением прав на использование USB-устройств. Использование межсетевых экранов нового поколения (NGFW) с функциями глубокого анализа трафика и фильтрации на уровне приложений. Внедрение системы двухфакторной аутентификации для доступа к АСЗИ. Регулярное создание и проверка резервных копий критичных данных с их защитой от несанкционированного доступа. Использование систем SIEM для корреляции событий безопасности и выявления сложных атак.	Таким образом, делаем вывод что угроза актуальна, так как на объекте отсутствует необходимый набор средств для нейтрализации как угрозы, так и нарушителя и сценариев, по которым он может реализовать угрозу.	

Порядок расчета актуальности угрозы при помощи аддитивной свертки

Расчет актуальности угрозы выполняется с использованием данных таблиц 12-13.

Таблица 12 – УБИ.088 – Угроза несанкционированного копирования защищаемой информации

№	Вопрос	Оценка частного показателя, Ch_j	Важность, α
1	Утверждено ли Положение о системе разграничения доступа или соответствующий раздел в Политике ИБ?		0,12
	Нет	0	
	Да	1	
2	Утверждена ли в организации Парольная политика или соответствующий раздел в Политике ИБ?		0,09
	Нет	0	
	Да	1	

Продолжение таблицы 12

№	Вопрос	Оценка частного показателя, Chj	Важность, α
3	Имеется ли план внутренних проверок по обеспечению защищенности ПДн в организации? Проводятся ли тесты на проникновение?		0,11
	Нет	0	
	Да, план имеется	0,5	
	Да, имеется план, а также осуществляется тестирование на проникновение	1	
4	Используются ли на объекте средства обнаружения вторжений и сканеры уязвимостей?		0,14
	Нет	0	
	Да	0,5	
	Да, и все средства имеют сертификационную документацию	1	
5	В организации используется только сертифицированное системное прикладное ПО?		0,10
	Нет	0	
	Да	1	
6	Используются ли на объекте средства межсетевого экранирования?		0,06
	Нет	0	
	Да	0,5	
	Да, и все средства имеют сертификационную документацию	1	
7	Производится ли ознакомление работников, осуществляющих обработку ПДн, с положениями законодательства РФ о персональных данных, в том числе документами, определяющими политику оператора в отношении обработки ПДн и обучение указанных работников?		0,16
	Нет	0	
	Производится ознакомление работников с требованиями законодательства и внутренней документацией	0,7	
	Производится не только ознакомление работников с требованиями законодательства и внутренней документацией, но и их обучение	1	
8	Используется ли на объекте антивирусное ПО?		0,07
	Нет	0	
	Да	0,5	
	Да, и все средства имеют сертификационную документацию	1	
9	Используются ли средства физической защиты объекта?		0,05
	Нет	0	
	Да	1	

Таблица 13 – Подсчет результатов угрозы УБИ.088

Оценка частного показателя, Ch_j	Важность, α
Вопрос 1 - 1	0,12
Вопрос 2 - 0	0,09
Вопрос 3 - 0	0,11
Вопрос 4 - 0	0,14
Вопрос 5 - 1	0,10
Вопрос 6 - 1	0,06
Вопрос 7 - 0,7	0,16
Вопрос 8 - 1	0,07
Вопрос 9 - 1	0.05
GP = 1×0,12+1×0,9+0×0,11+0×0,14+1×0,10+1×0,06 +0,7×0,16+1×0,07+1×0,05 = 0,512	

- 0–0,29 — степень защищенности информации низкая, оценка соответствия требования защиты – низкая, реализация угрозы высокая, необходима установка средств защиты в соответствии с выявленными недостатками – угроза актуальна;

- 0,3–0,59 — степень защищенности информации средняя, оценка соответствия требования защиты – средняя, реализации угрозы средняя, необходима установка средств защиты в соответствии с выявленными недостатками – угроза актуальна;

- 0,6–0,79 — степень защищенности информации высокая, оценка соответствия требования защиты – высокая, реализации угрозы низкая, необходима установка средств защиты в соответствии с выявленными недостатками – угроза актуальна;

- 0,8–1 — степень защищенности информации очень высокая, оценка соответствия требования защиты – очень высокая, реализация угрозы очень низкая, дополнительных средств защиты не требуется – угроза не актуальна.

Можно сделать вывод, что рассмотренная угроза является актуальной, информация защищена средне, требуются доработки в системе защиты информации. Оценка остальных угроз производится аналогичным методом.

4 Требования к системе

Система должна обеспечивать защиту персональных данных, обрабатываемых в АСЗИ, от несанкционированного доступа, утраты, модификации, блокирования, копирования, распространения и иных неправомерных действий в отношении информации.

Для этого в составе системы должны быть реализованы организационные и технические меры, обеспечивающие соответствие требованиям законодательства Российской Федерации в области защиты информации и персональных данных, а также требованиям нормативных документов ФСТЭК России.

Система защиты персональных данных должна учитывать выявленные актуальные угрозы безопасности информации, в частности — УБИ.088: Угроза несанкционированного копирования защищаемой информации.

Реализуемый комплекс мер должен обеспечивать достижение требуемого уровня защищённости персональных данных, установленного для АСЗИ, и исключать возможность реализации указанных угроз в процессе функционирования системы.

4.1 Требования к составу и содержанию мер по обеспечению безопасности ПДн, необходимых для обеспечения уровня защищенности ПДн, установленного для АСЗИ

Требования к составу и содержанию мер по обеспечению безопасности ПДн, необходимых для обеспечения уровня защищенности (УЗ) ПДн, установленного для АСЗИ (Основание для определения УЗ: АКТ определения УЗ ПДн в АСЗИ) представлены в таблице 14.

Таблица 14 – Требования к составу и содержанию мер по обеспечению безопасности ПДн

Условное обозначение и номер меры	Содержание мер по обеспечению безопасности ПДн	Уровень защищенности ПДн
		4
I. Идентификация и аутентификация субъектов доступа и объектов доступа (ИАФ)		
ИАФ.1	Идентификация и аутентификация пользователей, являющихся работниками оператора	+
ИАФ.3	Управление идентификаторами, в том числе создание, присвоение, уничтожение идентификаторов	+
ИАФ.4	Управление средствами аутентификации, в том числе хранение, выдача, инициализация, блокирование средств аутентификации и принятие мер в случае утраты и (или) компрометации средств аутентификации	+
ИАФ.5	Защита обратной связи при вводе аутентификационной информации	+
ИАФ.6	Идентификация и аутентификация пользователей, не являющихся работниками оператора (внешних пользователей)	+
II. Управление доступом субъектов доступа к объектам доступа (УПД)		
УПД.1	Управление (заведение, активация, блокирование и уничтожение) учетными записями пользователей, в том числе внешних пользователей	+
УПД.2	Реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа	+
УПД.3	Управление (фильтрация, маршрутизация, контроль соединений, однонаправленная передача и иные способы управления) информационными потоками между устройствами, сегментами информационной системы, а также между информационными системами	+
УПД.4	Разделение полномочий (ролей) пользователей, администраторов и лиц, обеспечивающих функционирование информационной системы	+
УПД.5	Назначение минимально необходимых прав и привилегий пользователям, администраторам и лицам, обеспечивающим функционирование информационной системы	+
УПД.6	Ограничение неуспешных попыток входа в информационную систему (доступа к информационной системе)	+
УПД.13	Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети	+
УПД.14	Регламентация и контроль использования в информационной системе технологий беспроводного доступа	+

Продолжение таблицы 14

Условное обозначение и номер меры	Содержание мер по обеспечению безопасности ПДн	Уровень защищенности ПДн
		4
УПД.15	Регламентация и контроль использования в информационной системе мобильных технических средств	+
УПД.16	Управление взаимодействием с информационными системами сторонних организаций (внешние информационные системы)	+
V. Регистрация событий безопасности (РСБ)		
РСБ.1	Определение событий безопасности, подлежащих регистрации, и сроков их хранения	+
РСБ.2	Определение состава и содержания информации о событиях безопасности, подлежащих регистрации	+
РСБ.3	Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения	+
РСБ.7	Защита информации о событиях безопасности	+
VI. Антивирусная защита (АВЗ)		
АВЗ.1	Реализация антивирусной защиты	+
АВЗ.2	Обновление базы данных признаков вредоносных компьютерных программ (вирусов)	+
VIII. Контроль (анализ) защищенности персональных данных (АНЗ)		
АНЗ.2	Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации	+
XI. Защита среды виртуализации (ЗСВ)		
ЗСВ.1	Идентификация и аутентификация субъектов доступа и объектов доступа в виртуальной инфраструктуре, в том числе администраторов управления средствами виртуализации	+
ЗСВ.2	Управление доступом субъектов доступа к объектам доступа в виртуальной инфраструктуре, в том числе внутри виртуальных машин	+
XII. Защита технических средств (ЗТС)		
ЗТС.3	Контроль и управление физическим доступом к техническим средствам, средствам защиты информации, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены, исключающие несанкционированный физический доступ к средствам обработки информации, средствам защиты информации и средствам обеспечения функционирования информационной системы, в помещения и сооружения, в которых они установлены	+
ЗТС.4	Размещение устройств вывода (отображения) информации, исключающее ее несанкционированный просмотр	+

Продолжение таблицы 14

Условное обозначение и номер меры	Содержание мер по обеспечению безопасности ПДн	Уровень защищенности ПДн
		4
XIII. Защита информационной системы, ее средств, систем связи и передачи данных (ЗИС)		
ЗИС.3	Обеспечение защиты персональных данных от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы контролируемой зоны, в том числе беспроводным каналам связи	+

"+" – мера по обеспечению безопасности персональных данных включена в базовый набор мер для соответствующего уровня защищенности персональных данных.

Меры по обеспечению безопасности персональных данных, не обозначенные знаком "+", применяются при адаптации базового набора мер и уточнении адаптированного базового набора мер, а также при разработке компенсирующих мер по обеспечению безопасности персональных данных.

4.2 Требования к мерам по идентификации и аутентификации субъектов доступа и объектов доступа

Меры по авторизации субъектов доступа и объектов доступа должны обеспечивать присвоение субъектам и объектам доступа уникального признака (идентификатора), сравнение предъявляемого субъектом (объектом) доступа идентификатора с перечнем присвоенных идентификаторов, а также проверку принадлежности субъекту (объекту) доступа предъявленного им идентификатора (подтверждение подлинности).

На основе модели «как будет» (to-be) подпроцесса «Выполнить аутентификацию в ОС и СУБД» модели IDEF0, показанной на рисунке 4, произведена её декомпозиция для разбиения на две составляющие: «Выполнить аутентификацию в ОС» и «Выполнить аутентификацию в СУБД» (рисунок 5). Каждый из процессов включает последовательность действий,

выполнение которых необходимо для получения доступа к системе и СУБД. Декомпозиция подпроцесса «Выполнить аутентификацию в ОС» модели “как будет” с использованием стандарта IDEF3 представлена на рисунке 6, а декомпозиция подпроцесса «Выполнить аутентификацию в СУБД» – на рисунке 7.

В отличии от модели “как есть”, в модели “как будет” эталонные данные для аутентификации пользователей хранятся в едином централизованном и защищенном месте – на сервере с установленным контроллером домена Active Directory. Контроллер домена Active Directory (AD) — это сервер, который управляет доменом Windows Server, предоставляя централизованные службы аутентификации, авторизации и управления сетевыми ресурсами. Он хранит базу данных пользователей, компьютеров и групп, а также обеспечивает единую точку входа и безопасный доступ к сетевым ресурсам благодаря применению групповых политик и других правил.

В частности, контроллер домена выполняет следующие функции:

- Запуск службы каталогов, например Windows Active Directory.
- Централизованное управление списком пользователей сети и их правами.
- Создание шаблонов настройки компьютеров сети.
- Хранение идентификаторов и паролей пользователей.
- Проверка подлинности пользователя при входе в сеть (аутентификация).
- Поиск по записям службы каталогов.
- Управление политиками безопасности домена.

Использование компьютеров с ОС Windows считается безопасным при реализации в купе с различными средствами защиты информации (например, Kaspersky Endpoint Security, Kaspersky Security Center) и контроллером домена.

Данная практика применяется в передовой отечественной ИТ-компании АО “Лаборатория Касперского”, специализирующейся на разработке продуктов обеспечения информационной безопасности.

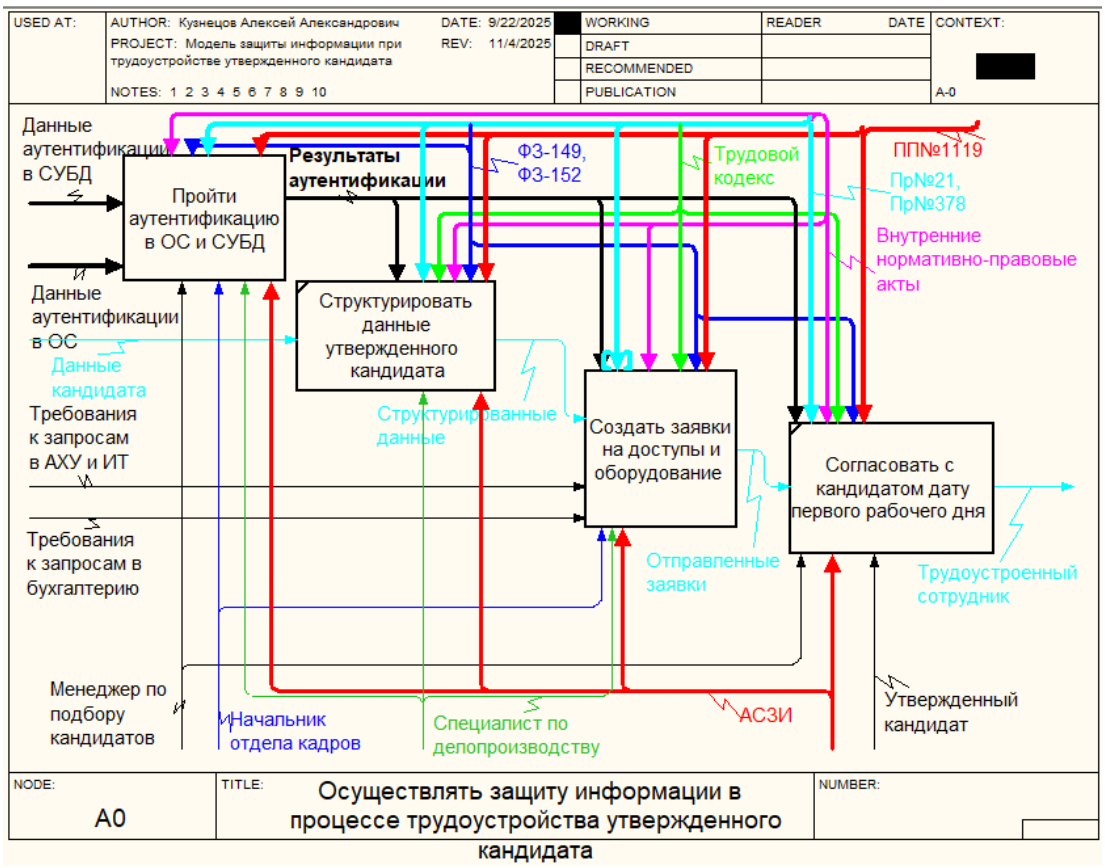


Рисунок 4 – Диаграмма декомпозиции контекстной диаграммы верхнего уровня модели “как будет”, выполненная в стандарте IDEF0

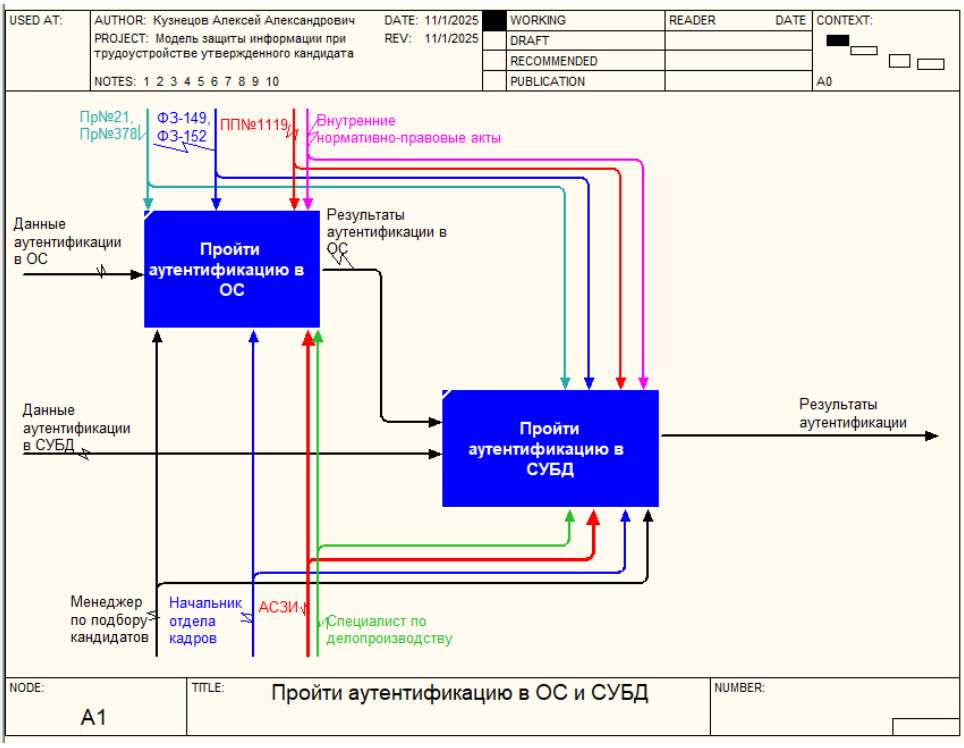


Рисунок 5 – Диаграмма декомпозиции процесса “Пройти аутентификацию в ОС и СУБД” модели “как будет”, выполненная в стандарте IDEF0

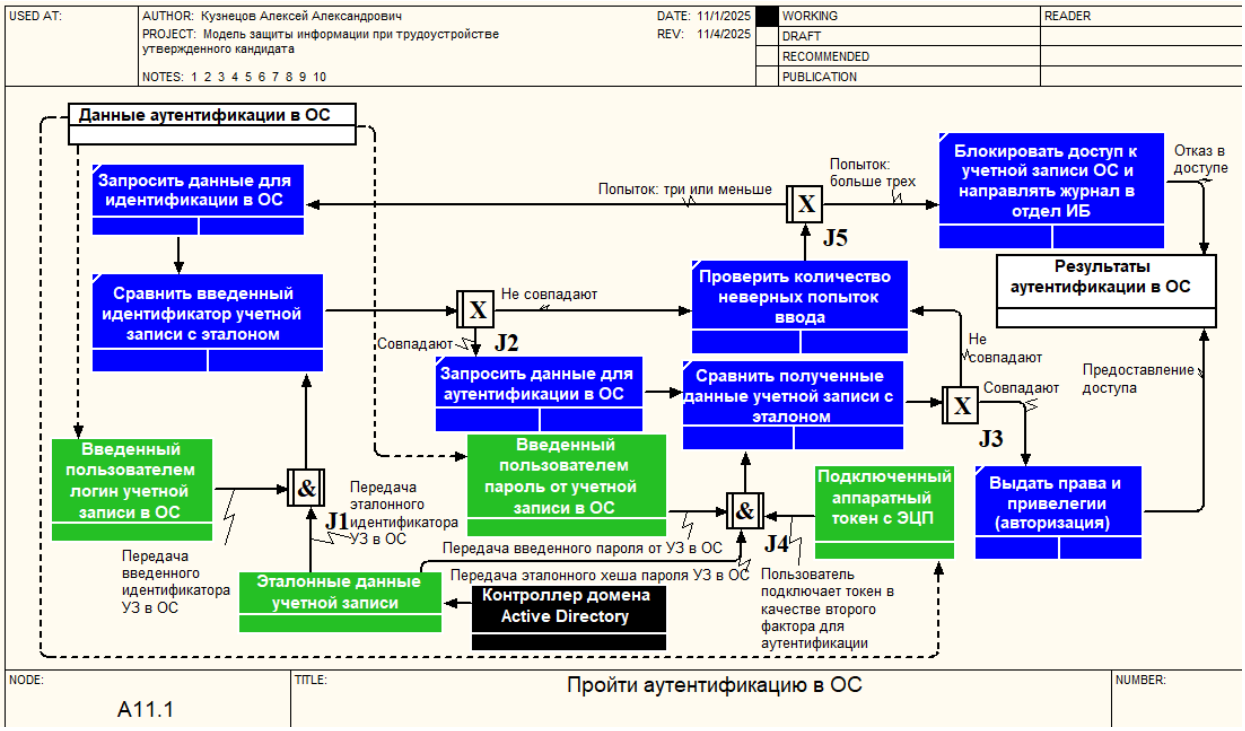


Рисунок 6 – Диаграмма декомпозиции процесса “Пройти аутентификацию в ОС” модели “как будет”, выполненная в стандарте IDEF3

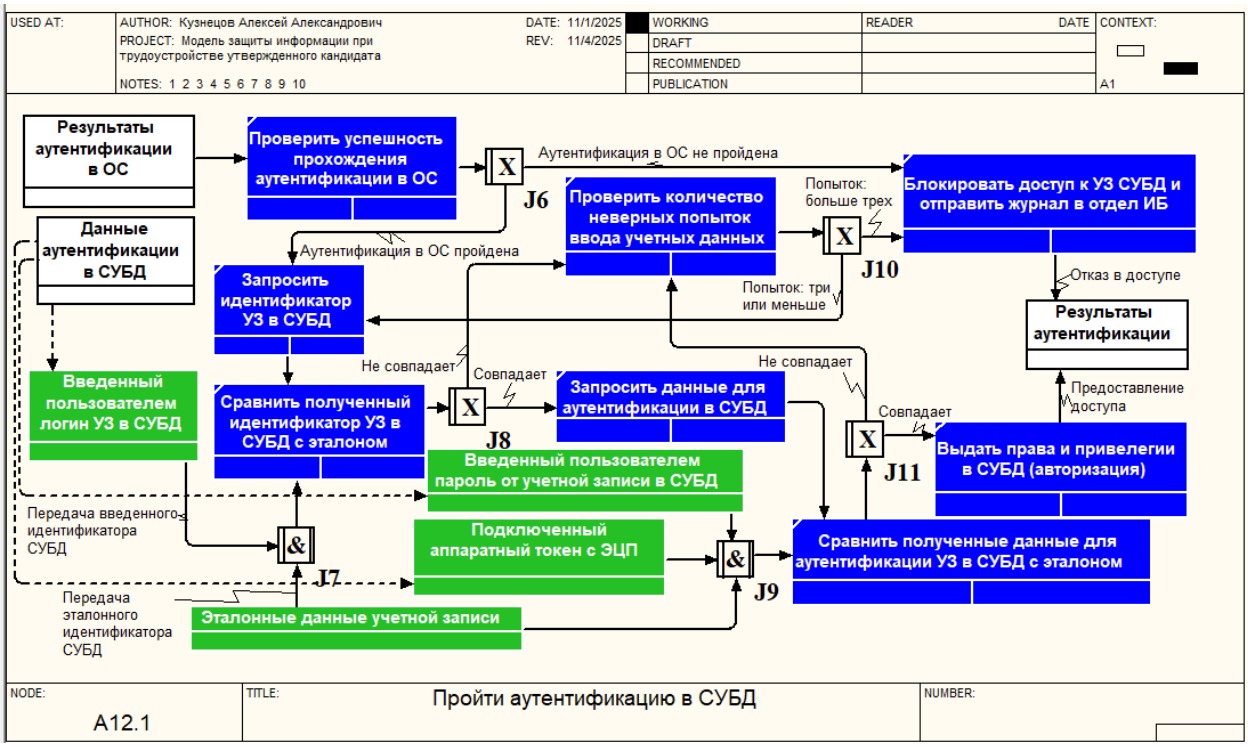


Рисунок 7 – Диаграмма декомпозиции процесса “Пройти аутентификацию в СУБД” модели “как будет”, выполненная в стандарте IDEF3

4.3 Требования к мерам по управлению доступом субъектов доступа к объектам доступа

Меры по управлению доступом в АСЗИ направлены на предотвращение несанкционированного доступа пользователей к ресурсам и данным системы. Управление доступом осуществляется с использованием ролевой модели, основанной на принципе минимально необходимых прав. Каждому пользователю назначается роль в соответствии с его должностными обязанностями (администратор, менеджер, специалист и др.).

4.4 Требования к мерам по ограничению программной среды

В целях исключения несанкционированного запуска, установки и модификации программ в АСЗИ реализованы меры по ограничению программной среды:

– пользователи не обладают административными правами на установку ПО;

– используется утверждённый перечень разрешённого программного обеспечения;

– применяются средства контроля целостности и политики доверенной загрузки;

– доступ к средствам настройки ОС и СУБД ограничен администраторами безопасности.

4.5 Требования к мерам по защите машинных носителей персональных данных (средств обработки (хранения) персональных данных, съемных машинных носителей персональных данных)

Машинные носители ПДн (жёсткие диски серверов, съёмные носители, резервные копии) подлежат контролю и защите от несанкционированного доступа. В АСЗИ реализовано:

– физическое ограничение доступа к серверам и архивным носителям (закрытые помещения, учёт выдачи);

– маркировка и учёт съёмных носителей;

– шифрование резервных копий и ограничение доступа к ним;

– уничтожение неисправных носителей по актам с применением средств, исключающих восстановление данных.

4.6 Требования к мерам по регистрации событий безопасности

В АСЗИ обеспечивается регистрация событий безопасности для контроля доступа и анализа инцидентов.

Журналируются:

– события входа/выхода пользователей в ОС и СУБД;

– изменения прав доступа и политик безопасности;

– попытки несанкционированного входа;

– действия администраторов.

Журналы защищаются от удаления и модификации, регулярно просматриваются ответственным за информационную безопасность, а архивные копии хранятся не менее 6 месяцев.

4.7 Требования к мерам по антивирусной защите

Антивирусная защита АСЗИ реализована с использованием сертифицированного ФСТЭК антивирусного программного обеспечения, установленного на всех рабочих станциях и серверах. Антивирусы обновляются централизованно, выполняют:

– постоянную проверку файлов в режиме реального времени;

– сканирование подключаемых носителей;

– автоматическое удаление или изоляцию вредоносных объектов.

4.8 Требования к мерам по обнаружению (предотвращению) вторжений

Требования к системам обнаружения вторжений (IDS) включают:

– Мониторинг сетевого трафика между всеми сегментами АСЗИ (серверный, отдел кадров, административный);

– Анализ трафика на наличие сигнатур известных атак и аномальной активности;

– Обнаружение попыток несанкционированного доступа к базе данных персональных данных;

– Выявление сканирования портов и сетевой разведки внутри сети.

Требования к системам предотвращения вторжений (IPS):

– Автоматическая блокировка подозрительного сетевого трафика;

– Предотвращение попыток эксплуатации уязвимостей в компонентах АСЗИ;

– Блокировка несанкционированных исходящих подключений;

– Контроль межсегментного трафика с политикой "запрещено все, что не разрешено".

4.9 Требования к мерам по контролю (анализу) защищенности персональных данных

Контроль защищённости проводится в виде внутренних проверок, тестов на проникновение и анализа уязвимостей.

В ООО «Маркетинг с умом» применяется следующая схема:

– периодическая проверка актуальности установленных обновлений ПО;

– использование специализированных сканеров уязвимостей;

– анализ журналов безопасности;

– оформление отчёта и корректирующих мероприятий по результатам проверки.

4.10 Требования к мерам по обеспечению целостности информационной системы и персональных данных

Обеспечение целостности ПДн и системных файлов осуществляется средствами контроля версий и резервного копирования.

Реализованы:

– контроль контрольных сумм и журналирование изменений;

– регулярное резервное копирование баз данных и критических файлов;

– хранение копий в защищённой среде;

– периодическое восстановление данных для проверки корректности резервов.

4.11 Требования к мерам по обеспечению доступности персональных данных

Для обеспечения доступности АСЗИ реализованы:

– резервное копирование и дублирование ключевых данных;

– использование источников бесперебойного питания;

– документированные процедуры восстановления после сбоев;

– разделение прав доступа между пользователями и администраторами для предотвращения случайного удаления данных.

4.12 Требования к мерам по защите среды виртуализации

В случае использования виртуальных машин в АСЗИ применяются меры по их изоляции и контролю:

– разграничение доступа между гипервизором и виртуальными машинами;

– запрет передачи данных между ВМ без проверки и согласования;

– обновление гипервизора и гостевых ОС;

– использование сертифицированных средств защиты виртуальной инфраструктуры.

4.13 Требования к мерам по защите технических средств

Технические средства защиты информации включают:

– использование сертифицированных устройств межсетевого экранирования;

– физическую защиту серверного оборудования и рабочих станций;

– установку средств контроля несанкционированного доступа (замки, СКУД, видеонаблюдение).

Оборудование, вышедшее из строя, подлежит уничтожению в установленном порядке.

4.14 Требования к мерам по защите информационной системы, ее средств, систем связи и передачи данных

Меры по защите сетевого взаимодействия включают:

– применение межсетевых экранов, маршрутизаторов с фильтрацией пакетов;

– сегментирование сети (рабочая, серверная и DMZ-зоны);

– фильтрацию трафика и контроль подключения внешних устройств.

Передача данных осуществляется по защищённым каналам связи с применением сертифицированных средств защиты.

4.15 Требования к мерам по выявлению инцидентов и реагированию на них

Система обеспечения безопасности предусматривает:

– выявление инцидентов ИБ на основе анализа журналов и уведомлений от антивирусных систем;

– регистрацию всех выявленных инцидентов в журнале учёта;

– расследование инцидентов и оформление актов;

– уведомление руководства и принятие мер по устранению последствий.

Результаты расследований фиксируются в отчётах и учитываются при планировании профилактических мер.

4.16 Требования к мерам по управлению конфигурацией информационной системы и системы защиты персональных данных

В АСЗИ управление конфигурацией осуществляется централизованно и документируется. Реализованы следующие требования:

– ведение реестра программных и аппаратных компонентов АСЗИ;

– контроль изменений конфигурации, установка обновлений только после тестирования;

– использование разграничения на версии и резервного хранения настроек;

– согласование изменений с ответственным за ИБ перед внедрением.

4.17 Требования к структуре и функционированию СЗПДн АСЗИ

Структура СЗПДн АСЗИ должна включать подсистемы защиты информации, определяемые требованиям нормативных документов ФСТЭК России и ФСБ России в части безопасности ПДн и моделью угроз безопасности ПДн.

Функции подсистем защиты информации СЗПДн АСЗИ должны быть направлены на защиту ПДн, обрабатываемых в АСЗИ, от угроз безопасности ПДн, приведенных в модели угроз безопасности ПДн.

4.17.1 Перечень систем, подсистем СЗПДн АСЗИ, их назначение и основные характеристики

Подсистемы СЗПДн АСЗИ должны обеспечивать защиту ПДн от актуальных угроз безопасности персональных данных (УБПДн), приведенных в Модели угроз безопасности ПДн.

Состав подсистем СЗПДн АСЗИ и выполняемые ими функции представлены в таблице 15.

Таблица 15 – Состав подсистем обеспечения безопасности ПДн

№ п/п	Наименование подсистемы	Функции подсистемы
1	Подсистема идентификации и аутентификации субъектов доступа СЗПДн АСЗИ»	идентификация и аутентификация пользователей, устройств; управление идентификаторами, средствами аутентификации;

№ п/п	Наименование подсистемы	Функции подсистемы
2	Подсистема контроля защищенности персональных данных СЗПДн АСЗИ	выявление, анализ уязвимостей информационной системы; контроль установки обновлений программного обеспечения, работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации; контроль состава технических средств, программного обеспечения и средств защиты информации; контроль правил генерации и смены паролей пользователей;
3	Подсистема управления доступом СЗПДн АСЗИ	управление (заведение, активация, блокирование и уничтожение) учетными записями пользователей; реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа; разделение полномочий (ролей) пользователей;
4	Подсистема обеспечения целостности СЗПДн АСЗИ	контроль целостности программного обеспечения, персональных данных; обеспечение возможности восстановления программного обеспечения; обнаружение и реагирование на поступление в информационную систему незапрашиваемых электронных сообщений; контроль содержания информации, передаваемой из информационной системы; ограничение прав пользователей по вводу информации в информационную систему;

Продолжение таблицы 15

№ п/п	Наименование подсистемы	Функции подсистемы
5	Подсистема регистрации и учета СЗПДн АСЗИ	регистрация и учет событий безопасности;
6	Подсистема антивирусной защиты СЗПДн АСЗИ	антивирусная защита АСЗИ;
7	Подсистема обнаружения вторжений СЗПДн АСЗИ	обнаружение вторжений в АСЗИ;
8	Подсистема выявления инцидентов и реагирования на них СЗПДн АСЗИ	обнаружение, идентификация и регистрация инцидентов; анализ инцидентов; планирование и принятие мер по предотвращению повторного возникновения инцидентов;
9	Подсистема ограничения программной среды СЗПДн АСЗИ	управление запуском (обращениями) компонентов программного обеспечения; управление установкой (инсталляцией) компонентов программного обеспечения;
10	Подсистема управления конфигурационной информацией СЗПДн АСЗИ	управление изменениями конфигурации информационной системы и системы защиты персональных данных; анализ потенциального воздействия планируемых изменений в конфигурации информационной системы и СЗПДн на обеспечение защиты ПДн;
11	Подсистема защиты машинных носителей СЗПДн АСЗИ	учет машинных носителей информации; управление доступом к машинным носителям информации; контроль перемещения машинных носителей информации; контроль подключения машинных носителей;
12	Подсистема обеспечения доступности СЗПДн АСЗИ	резервирование технических средств, программного обеспечения, каналов передачи информации, средств обеспечения функционирования информационной системы; выполнение резервного копирования защищаемой информации;

Продолжение таблицы 15

№ п/п	Наименование подсистемы	Функции подсистемы
13	Подсистема защиты технических средств СЗПДн АСЗИ	защита информации, обрабатываемой техническими средствами, от ее утечки по техническим каналам; организация контролируемой зоны; контроль и управление физическим доступом к техническим средствам, средствам защиты информации, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены;
14	Подсистема защиты автоматизированной информационной системы и межсетевого взаимодействия СЗПДн АСЗИ	защита процессов функционирования информационной системы;
15	Подсистема криптографической защиты информации СЗПДн АСЗИ	криптографическая защита информации, передаваемой по сетям связи общего пользования.

4.17.2 Требования к способам и средствам связи для информационного обмена между компонентами системы

Информационный обмен между компонентами системы защиты персональных данных (СЗПДн) осуществляется по защищённым каналам связи в пределах локальной вычислительной сети (ЛВС).

Передача данных должна обеспечивать:

– целостность, подлинность и конфиденциальность передаваемой информации;

– защиту от несанкционированного доступа, подмены и повторного использования пакетов данных;

– недопустимость подключения неавторизованных узлов к защищённым каналам связи.

4.17.3 Требования к характеристикам взаимосвязей создаваемой системы со смежными системами

СЗПДн АСЗИ должна взаимодействовать с подсистемами АСЗИ, используя существующие механизмы связи и протоколы взаимодействия, которые должны быть уточнены в Техническом проекте.

4.17.4 Требования к режимам функционирования системы

СЗПДн АСЗИ должна поддерживать функционирование в следующих режимах:

- основной;
- режим проведения технологических работ;
- аварийный режим.

Основной режим работы

Полноценная эксплуатация АСЗИ в рабочие часы. Все функции доступны в соответствии с заданными правами. Круглосуточный мониторинг/дежурство — для служб ИБ и администрирования: мониторинг событий и реагирование 24/7 (дежурные смены или SOC).

Режим проведения технологических работ

Плановое окно, заранее согласованное, при котором проводятся обновления, резервирования и проверки; пользователи уведомляются заранее.

Аварийный режим

Действия по восстановлению системы в случае отказа или инцидента; регламентируются планом аварийного восстановления.

4.17.5 Перспективы развития и модернизации системы

Архитектура АСЗИ должна предусматривать горизонтальное и вертикальное масштабирование сервисов (возможность добавления серверов

приложений, увеличение ёмкостей СУБД, балансировка нагрузки). Компоненты, критичные по производительности, должны иметь план добавления ресурсов без полной остановки сервиса.

Система проектируется модульно: каждую новую подсистему можно подключать через документированный API с минимальными изменениями базовой логики. Устанавливаемая программная платформа должна поддерживать регулярные обновления (патчи безопасности) с тестовым прогоном в стенде перед применением в промышленной среде. Для критичных компонентов необходимо предусмотреть SLA с поставщиками ПО и/или резервных поставщиков.

Технологические направления для возможной модернизации:

– Внедрение SIEM/SOAR для автоматизации анализа инцидентов.

– Централизованное EDR на рабочих станциях.

– Переход на многофакторную аутентификацию (FIDO2, аппаратные токены) для всех пользователей.

– Внедрение контейнеризации/микросервисной архитектуры для отдельных сервисов с отдельной политикой безопасности.

4.17.6 Требования по стандартизации и унификации

При создании и эксплуатации системы должны применяться единые стандарты, протоколы и форматы данных, обеспечивающие совместимость программных и технических средств. В качестве основных стандартов используются протоколы HTTPS, SSH, SFTP и форматы обмена JSON и XML. Все процедуры идентификации, аутентификации и управления доступом выполняются по единой корпоративной политике безопасности. Программное обеспечение, применяемое в АСЗИ, должно соответствовать требованиям ГОСТ и быть сертифицированным ФСТЭК России. Документация на систему, включая руководства пользователей и администраторов, оформляется по установленным стандартам. Унификация решений позволяет сократить

издержки на сопровождение, повысить надёжность функционирования системы и обеспечить её соответствие нормативным требованиям.

4.17.7 Требования к численности и квалификации персонала системы и режиму его работы

Обслуживание и сопровождение АСЗИ осуществляют квалифицированные специалисты, обладающие знаниями в области информационной безопасности, системного администрирования и защиты персональных данных.

К работе допускаются только сотрудники, прошедшие соответствующее обучение и инструктаж по обеспечению безопасности информации. Рекомендуется наличие ответственного за обеспечение безопасности ПДн, системного администратора, а также специалиста по технической поддержке пользователей.

Режим работы персонала должен обеспечивать постоянный контроль состояния системы, своевременное реагирование на инциденты и проведение регламентных мероприятий по техническому обслуживанию. Повышение квалификации персонала проводится не реже одного раза в год с обязательным документальным подтверждением.

4.17.8 Требования к показателям назначения системы

Система должна обеспечивать требуемые показатели по производительности, надёжности и уровню защищённости персональных данных. Время восстановления после отказа не должно превышать четырёх часов, а максимальная потеря данных при аварийных ситуациях — не более одного часа. Среднее время отклика прикладных сервисов не должно превышать двух секунд при стандартной нагрузке.

Все показатели надёжности и эффективности работы системы должны контролироваться средствами мониторинга, а результаты проверок отражаться в отчётах по эксплуатации. Периодическая оценка выполнения

установленных показателей проводится ответственным за эксплуатацию системы и фиксируется в соответствующих документах.

4.17.9 Требования к надежности

Надежность и оперативная готовность СЗПДн АСЗИ должна обеспечиваться выполнением следующих требований:

- возможность непрерывной работы с учетом перерывов, необходимых для технического обслуживания;

- оперативное восстановление данных и работоспособности оборудования СЗПДн АСЗИ в случаях выхода из строя оборудования и при чрезвычайных ситуациях. Допустимыми способами оперативного восстановления являются (но не исчерпываются): наличие резервных копий файлов конфигурации компонентов СЗПДн АСЗИ; использование технологии виртуализации серверов; применение избыточности в аппаратных компонентах СЗПДн АСЗИ (дублирование блоков питания, использование RAID-массивов, наличие запасного комплекта оборудования и т.п.).

Выбор конкретного способа обеспечения отказоустойчивости производится на этапе разработки Технического проекта.

4.17.10 Требования к эксплуатации, техническому обслуживанию, ремонту и хранению элементов системы

Интерфейс системы должен быть интуитивно понятным, удобным для пользователя и соответствовать основным принципам эргономики. Все элементы управления и отображения информации располагаются логично и последовательно, обеспечивая минимизацию количества действий для выполнения типовых операций. Визуальный дизайн интерфейса должен быть нейтральным, без избыточных графических элементов, с использованием читаемых шрифтов и контрастных цветовых решений.

Интерфейс должен обеспечить возможность нахождения необходимого элемента в течение 5 секунд поиска.

Рабочие окна системы должны быть оптимизированы для разрешений современных мониторов и обеспечивать корректное отображение информации без горизонтальной прокрутки. Система должна предоставлять пользователю информативные сообщения об ошибках и подсказки при выполнении операций. При разработке интерфейса следует учитывать возможности пользователей с ограниченными навыками работы с компьютером. Требования к эргономике распространяются как на клиентские приложения, так и на веб-интерфейсы административных модулей.

4.18 Требования к видам обеспечения

Создаваемая автоматизированная система в защищённом исполнении должна включать полный комплекс видов обеспечения, необходимых для её функционирования, сопровождения и защиты информации. В состав обеспечения входят техническое, программное, информационное, организационное, методическое и правовое обеспечение. Каждый вид обеспечения должен обеспечивать выполнение установленных требований к защите персональных данных, устойчивость функционирования системы и удобство эксплуатации. Виды обеспечения реализуются в соответствии с действующими нормативно-правовыми актами, государственными стандартами и внутренними регламентами организации.

Особое внимание уделяется совместимости программных и технических средств, сертификации компонентов по требованиям ФСТЭК России и ФСБ России, а также поддержанию актуальности программных решений и эксплуатационной документации.

4.18.1 Требования к техническому обеспечению

Техническое обеспечение системы должно включать совокупность технических средств, необходимых для реализации всех функций системы и обеспечения заданных характеристик надёжности, производительности и защищённости.

В состав оборудования входят серверы баз данных, сервер приложений, рабочие станции пользователей, сетевые коммутаторы, маршрутизаторы, межсетевые экраны и устройства бесперебойного питания. Все технические средства должны иметь действующие сертификаты соответствия и обеспечивать возможность установки сертифицированных средств защиты информации.

Серверное оборудование размещается в специально оборудованном помещении с контролируемым доступом, системой видеонаблюдения и средствами пожаротушения. Рабочие места пользователей подключаются к системе по защищённым каналам локальной сети. Для обеспечения устойчивости работы системы предусматривается резервирование критических компонентов, наличие источников бесперебойного питания, а также организация регулярного резервного копирования данных. Подбор и эксплуатация технических средств должны обеспечивать выполнение требований по защите персональных данных, установленных нормативными документами.

4.18.2 Требования к программному обеспечению

Программное обеспечение системы должно включать совокупность системных, прикладных и специальных программных средств, обеспечивающих функционирование АСЗИ в соответствии с целевым назначением. Все программные продукты, используемые при обработке персональных данных, должны быть сертифицированы в установленном порядке и обеспечивать реализацию комплекса организационных и технических мер защиты информации, предусмотренных приказом ФСТЭК России №21.

В состав программного обеспечения входят операционные системы серверов и рабочих станций, системы управления базами данных, прикладные модули, а также средства антивирусной защиты, шифрования и контроля целостности. Администрирование системы осуществляется через

защищённый веб-интерфейс с применением многофакторной аутентификации и разграничением прав доступа по ролям.

Программное обеспечение должно обеспечивать совместимость между компонентами системы, возможность централизованного обновления, журналирования событий и восстановления после сбоев. Все обновления программных компонентов проходят предварительное тестирование и утверждение ответственными лицами

4.18.3 Требования к методическому и другим видам обеспечения

Методическое обеспечение системы включает совокупность документов, инструкций и методик, регламентирующих процессы эксплуатации, администрирования и защиты информации. К ним относятся руководство пользователя, руководство администратора системы, инструкции по резервному копированию и восстановлению данных, а также положения о разграничении прав доступа и политике безопасности персональных данных. Методические материалы разрабатываются в соответствии с действующими нормативными документами, внутренними стандартами ООО «Маркетинг с умом» и положениями ГОСТ 34.602-2020.

Кроме того, система должна иметь организационное обеспечение, включающее распределение ролей и обязанностей персонала, назначение ответственных за обеспечение безопасности информации и ведение журналов учёта действий пользователей. К другим видам обеспечения относятся правовое обеспечение, определяющее правовые основы обработки персональных данных, и информационное обеспечение, включающее структуру и содержание обрабатываемых данных, справочников и классификаторов.

Все виды обеспечения должны поддерживаться в актуальном состоянии и корректироваться по мере модернизации системы или изменения нормативных требований.

5 Состав и содержание работ по созданию системы

Стадии и этапы работ по созданию СЗПДн АСЗИ, а также содержание и результаты этих работ представлены в таблице 16.

Таблица 16 – Стадии и этапы работ по созданию СЗПДн АСЗИ, а также содержание и результаты этих работ

Стадия	Этап работы	Организации - исполнители работ	Состав и результаты работ
Формирование требований	Построение Модели угроз безопасности ПДн	Исполнитель	Модель Угроз безопасности ПДн
	Разработка ЧТЗ на создание СЗПДн АСЗИ		ЧТЗ на создание СЗПДн АСЗИ
Техническое задание	Разработка ОРД по защите ПДн		Разработка ОРД по защите ПДн в составе, определенном в Разделе 8
Разработка документации	Подготовка объекта автоматизации к вводу СЗПДн АСЗИ в действие		Подготовка объекта автоматизации к вводу в действие СЗПДн АСЗИ
Ввод в действие	Подготовка персонала	Заказчик	Обучение персонала СЗПДн АСЗИ. Проверка способности персонала обеспечивать функционирование СЗПДн АСЗИ
	Комплектация СЗПДн АСЗИ поставляемыми Изделиями	Организация, осуществляющая обучение персонала, определяется Заказчиком на основании отдельного договора	Поставка комплектующих изделий СЗПДн АСЗИ и проверка поставляемых комплектующих изделий
	Пуско-наладочные работы	Исполнитель Заказчик совместно с исполнителем	Проведение пуско-наладки технических и программных средств СЗПДн АСЗИ

Продолжение таблицы 16

Стадия	Этап работы	Организации - исполнители работ	Состав и результаты работ
Ввод в действие	Подготовка к испытаниям СЗПДн АСЗИ		Разработка Программы и методики испытаний, Программы опытной эксплуатации
	Предварительные испытания СЗПДн АСЗИ		Предварительные испытания СЗПДн АСЗИ в соответствии с Программой и методикой испытаний. Устранение выявленных недостатков и внесение изменений в документацию (при необходимости). Акт о приемке СЗПДн АСЗИ в опытную эксплуатацию
	Опытная эксплуатация СЗПДн АСЗИ		Опытная эксплуатация СЗПДн АСЗИ в соответствии с Программой опытной эксплуатации. Анализ, доработка, наладка компонентов СЗПДн АСЗИ (при необходимости)
			Опытная эксплуатация СЗПДн АСЗИ в соответствии с Программой опытной эксплуатации. Анализ, доработка, наладка компонентов СЗПДн АСЗИ (при необходимости)
Сопровождение	Гарантийное обслуживание СЗПДн АСЗИ	Исполнитель	Выполнение работ в соответствии с гарантийными обязательствами на СЗПДн АСЗИ;
	Послегарантийное обслуживание СЗПДн АСЗИ	Заказчик совместно с исполнителем	Выполнение послегарантийного обслуживания СЗПДн АСЗИ

6 Порядок контроля и приемки системы

До ввода СЗПДн АСЗИ в эксплуатацию должны быть проведены следующие виды испытаний:

- предварительные испытания;
- опытная эксплуатация;
- приемочные испытания.

6.1 Виды испытаний системы

Испытания системы подразделяются на предварительные, опытные и приемочные.

Предварительные испытания проводятся после завершения этапа внедрения для оценки готовности системы к эксплуатации и выявления возможных несоответствий.

Опытная эксплуатация проводится в условиях, максимально приближенных к реальным, с целью оценки стабильности функционирования системы, выявления ошибок и уточнения регламентов работы пользователей.

Приемочные испытания осуществляются комиссией, утвержденной руководством ООО «Маркетинг с умом», и служат основанием для ввода системы в промышленную эксплуатацию. Все испытания должны проводиться в соответствии с утвержденной программой и методикой испытаний, результаты оформляются протоколами и актами установленной формы.

6.1.1 Состав, объем и методы испытаний системы

Состав и объем испытаний определяются программой и методикой испытаний, утвержденной Заказчиком. В испытания включаются проверка всех функций системы, предусмотренных техническим заданием, оценка корректности реализации механизмов аутентификации и авторизации, проверка работы средств защиты информации, антивирусной защиты,

резервного копирования, а также контроль корректности функционирования интерфейсов и обмена данными между подсистемами.

Испытания проводятся методами функционального тестирования, имитационного моделирования, а также анализа журналов событий и отчетов систем защиты. Проверка мер безопасности осуществляется путем моделирования типовых угроз и попыток несанкционированного доступа. В процессе испытаний фиксируются выявленные несоответствия и разрабатываются рекомендации по их устранению.

6.1.2 Предварительные испытания системы

Предварительные испытания проводятся для проверки работоспособности всех компонентов системы после завершения установки и настройки программного обеспечения.

На данном этапе оценивается полнота реализации функционала, корректность взаимодействия между модулями, соответствие параметров производительности и устойчивости установленным требованиям.

Результаты предварительных испытаний оформляются протоколом, который содержит перечень выполненных проверок, описание обнаруженных отклонений и рекомендации по их устранению. После успешного завершения предварительных испытаний система допускается к опытной эксплуатации.

6.1.3 Опытная эксплуатация системы

Опытная эксплуатация проводится с целью проверки стабильности работы системы в условиях реальной эксплуатации и выявления возможных ошибок, не обнаруженных на предыдущих стадиях.

В ходе опытной эксплуатации осуществляется работа пользователей в полном объеме с регистрацией всех действий и анализом возникающих инцидентов. Оценивается удобство интерфейсов, корректность функционирования подсистем безопасности, полнота ведения журналов

регистрации событий, а также соответствие фактических показателей установленным критериям.

По результатам опытной эксплуатации составляется отчет, включающий анализ выявленных проблем и предложения по их устранению. После завершения данного этапа проводится подготовка к приемочным испытаниям.

6.1.4 Приемочные испытания системы

Приемочные испытания проводятся комиссией, назначенной приказом руководителя ООО «Маркетинг с умом», с участием представителей Заказчика и Исполнителя.

Целью испытаний является подтверждение соответствия созданной системы всем требованиям технического задания, нормативных документов по защите информации и условиям договора.

Приемочные испытания включают проверку функциональных возможностей, отказоустойчивости, защиты персональных данных, а также корректности ведения эксплуатационной документации.

По результатам испытаний оформляется акт приемки системы в эксплуатацию, подписанный членами комиссии. При наличии замечаний составляется перечень доработок с указанием сроков их выполнения. После устранения всех замечаний и повторной проверки система считается принятой и допускается к промышленной эксплуатации.

6.2 Общие требования к приемке работ по стадиям

Приемка работ осуществляется по завершении каждой стадии создания системы в соответствии с графиком, установленным договором и техническим заданием.

На каждой стадии проводится проверка полноты и качества выполненных работ, соответствия документации установленным стандартам и требованиям.

Результаты проверок оформляются актами сдачи-приемки и утверждаются Заказчиком. При обнаружении несоответствий Исполнитель обязан устранить их в установленные сроки. Окончательная приемка системы в эксплуатацию осуществляется после успешного завершения приемочных испытаний и подписания итогового акта приемки.

С момента подписания акта ответственность за эксплуатацию и сопровождение системы передается Заказчику.

6.2.1 Перечень участвующих предприятий и организаций

Участниками предварительных и приемочных испытаний являются:

- Организация, осуществляющая ввод в действие СЗПДн АСЗИ;
- Заказчик.

Опытная эксплуатация СЗПДн АСЗИ производится сотрудниками подразделений Заказчика, ответственных за эксплуатацию СЗПДн АСЗИ. Во время опытной эксплуатации могут привлекаться специалисты Организации, осуществляющей ввод в действие СЗПДн АСЗИ, порядком, устанавливаемым Программой опытной эксплуатации.

6.2.2 Место и сроки проведения испытаний

Предварительные испытания СЗПДн АСЗИ проводятся в территориально-распределенных объектах Заказчика, приведенных в таблице 2, перечень объектов определяется Программой и методикой испытаний. Местонахождение участников испытаний во время проведения испытаний определяется Программой и методикой испытаний. Предварительные испытания проводятся по завершению пуско-наладочных работ и подготовки к испытаниям.

Опытная эксплуатация СЗПДн АСЗИ проводится в территориально-распределенных объектах Заказчика, приведенных в таблице 2 (перечень объектов определяется Программой и методикой испытаний), в течение времени, определяемого Программой опытной эксплуатации. Опытная

эксплуатация производится после завершения предварительных испытаний и оформления акта о приемке СЗПДн АСЗИ в опытную эксплуатацию.

Приемочные испытания проводятся в территориально-распределенных объектах Заказчика, приведенных в таблице 2, перечень объектов определяется Программой и методикой испытаний. Местонахождение участников испытаний во время проведения испытаний определяется Программой и методикой испытаний.

6.2.3 Порядок согласования и утверждения приемочной документации

Предварительные и приемочные испытания СЗПДн АСЗИ проводятся комиссией, состав которой утверждается приказом Заказчика.

Председателем комиссии назначается представитель Заказчика.

Протоколы проведения испытаний подписываются всеми членами комиссии.

При положительном результате проведения предварительных или приемочных испытаний составляется акт о передаче системы в опытную эксплуатации (в случае предварительных испытаний) или акт о переводе системы в постоянную эксплуатацию (в случае приемочных испытаний). Акты подписываются председателем комиссии.

7 Требования к составу и содержанию работ по подготовке объекта автоматизации к вводу СЗПДн АСЗИ в действие

При подготовке к вводу в действие СЗПДн АСЗИ Организация, осуществляющая ввод действие, должна подготовить и согласовать с Заказчиком список технических средств, доступ к которым должен быть предоставлен для проведения работ по вводу в действие СЗПДн АСЗИ.

При подготовке к вводу в действие СЗПДн АСЗИ Заказчик должен обеспечить:

- предоставление доступа к компонентам СЗПДн АСЗИ сотрудникам Организации, осуществляющей ввод действие;

- предоставление технических средств и требуемых им ресурсов в соответствии с требованиями, определенными в Техническом проекте. Технические средства должны соответствовать требованиям, определенным в Техническом проекте;

- готовность инфраструктуры к установке компонентов СЗПДн АСЗИ;

- наличие обученного персонала для обеспечения эксплуатации компонентов СЗПДн АСЗИ. Перечень необходимых курсов для обучения персонала определяется в Техническом проекте;

- утверждение ОРД, созданной на этапе разработки ОРД по защите ПДн;

- издание приказов о формировании соответствующих приемочных комиссий по вводу в действие СЗПДн АСЗИ.

8 Требования к документированию

Документирование создаваемой системы должно выполняться в соответствии с требованиями государственных стандартов ГОСТ 34.201–2020, ГОСТ 34.602–2020, ГОСТ 19.201–78, а также внутренними нормативными актами ООО «Маркетинг с умом».

В состав документации на систему должны входить организационно-распорядительные, проектные, эксплуатационные и отчетные документы, обеспечивающие полное описание структуры, функциональности и режимов работы системы, а также порядок эксплуатации и сопровождения.

К организационно-распорядительным документам относятся договор на создание системы, техническое задание, приказы, распоряжения и акты утверждения этапов разработки.

Проектная документация должна включать технический проект, описание архитектуры, схемы взаимодействия компонентов, модели угроз и систему мер защиты персональных данных.

Эксплуатационная документация включает руководство пользователя, руководство администратора системы, инструкции по резервному копированию и восстановлению данных, а также регламенты по управлению доступом, регистрации событий и реагированию на инциденты.

Отчетная документация содержит результаты испытаний, акты приемки и отчеты о тестировании мер защиты. Все документы должны быть оформлены в печатном и электронном виде, иметь регистрационные номера, грифы утверждения и храниться в установленном порядке в подразделении, ответственном за обеспечение информационной безопасности.

Изменения в документацию вносятся в установленном порядке с обязательной регистрацией и утверждением. Документирование должно обеспечивать полную прослеживаемость всех стадий разработки, внедрения и эксплуатации системы.

9 Источники разработки

Настоящее Частное техническое задание разработано на основе следующих нормативных документов, методических материалов и информационных источников:

− Договор №1/10/11-2025 от 01.10.2025 до 01.03.2026 на создание автоматизированной системы в защищенном исполнении для маркетинговой компании ООО “Маркетинг с умом”.

– Федеральный закон от 27.07.2006 г. № 152-ФЗ «О персональных данных»;

– Федеральный закон от 29.07.2004 г. № 98-ФЗ «О коммерческой тайне»;

– Постановление Правительства РФ от 01.11.2012 г. № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных»;

– Приказ ФСТЭК России от 18.02.2013 г. № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных»;

– «Методический документ. Методика оценки угроз безопасности информации» (утв. ФСТЭК России 05.02.2021);

– Приказ ФСБ России от 10.07.2014 г. № 378 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации»;

– ГОСТ 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищённом исполнении. Общие положения»;

– ГОСТ Р 59853-2021 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Термины и определения»;

– ГОСТ 34.201-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Виды, комплектность и обозначение документов при создании автоматизированных систем»;

− ГОСТ Р 59792-2021 «Информационные технологии. Виды испытаний автоматизированных систем».

– ГОСТ Р 59793-2021 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания»;

– ГОСТ Р 59795-2021 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Требования к содержанию документов»;

– ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы»;

– ГОСТ 19.201-78 «Единая система программной документации. Техническое задание. Требования к содержанию и оформлению»;

– ГОСТ 19.106-78 «Единая система программной документации. Требования к программным документам, выполненным печатным способом»;

– ГОСТ 19.505-79 «Руководство оператора. Требования к содержанию и оформлению»;

– ГОСТ 19.503-79 «Руководство системного программиста. Требования к содержанию и оформлению»;

– ГОСТ 12.1.004-91 «ССБТ. Пожарная безопасность. Общие требования»;

− ГОСТ 24.104-2023 «Единая система стандартов автоматизированных систем управления. Автоматизированные системы управления. Общие требования».

− ГОСТ Р 70303-2022 «Национальный стандарт Российской Федерации. Слаботочные системы. Кабельные системы. Заземление телекоммуникационных систем. Общие требования».

10 Перечень принятых сокращений и условных обозначений

АВС – антивирусные средства,

АРМ – автоматизированное рабочее место,

АС – автоматизированная система,

АСЗИ – автоматизированная система в защищенном исполнении,

БД – база данных,

ВПО – вредоносное программное обеспечение,

ИБ – информационная безопасность,

ЛВС – локальная вычислительная сеть,

ПДн – персональные данные,

ПО – программное обеспечение,

СЗИ – средство защиты информации,

СЗПДн – система защиты персональных данных,

СКЗИ – средства криптографической защиты информации,

ТЗ – техническое задание,

УБИ – угроза безопасности информации,

УБПДн – угроза безопасности персональных данных,

ФСБ – Федеральная служба безопасности,

ФСТЭК – Федеральная служба по техническому и экспортному контролю,

ЧТЗ – частное техническое задание,

API – Application Programming Interface – интерфейс прикладного программирования,

EDR – Endpoint Detection and Response – обнаружение и реагирование на конечных точках,

KES – Kaspersky Endpoint Security,

KSC – Kaspersky Security Center,

KUMA – SIEM-система Kaspersky Unified Monitoring and Analysis Platform,

NGFW – Next Generation Firewall – межсетевой экран нового поколения,

PT – Positive Technologies,

SIEM – Security Information and Event Management – система управления событиями безопасности,

SOC – Security Operation Center – центр мониторинга и управления инцидентами информационной безопасности.